UD02 Mecanismos de seguridad activa

Alejandro Cajide
IES San Clemente, Santiago de Compostela

Septiembre 2026

Índice

1. Elaboración de un manual de seguridad y planes de contingencia **3**
1.1. Plan de contingencias . . . 3
1.2. Pautas y prácticas seguras . . . 4
1.2.1. Herramientas preventivas y paliativas . . . 4
1.2.2. Actualización de sistemas y aplicaciones . . . 5

2. Ataques y contramedidas en sistemas personales **5**
2.1. Anatomía de un ataque y análisis de software malicioso . . . 6
2.2. Clasificación de los ataques . . . 6
2.3. Footprinting o Information Gathering . . . 6
2.3.1. OSINT y Maltego . . . 7
2.3.2. Google Hacking y Bing Hacking . . . 7
2.3.3. Shodan . . . 8
2.4. Fingerprinting . . . 8
2.5. Explotación de vulnerabilidades . . . 8
2.6. Ataques según el principio de seguridad vulnerado . . . 8
2.6.1. Interceptación de mensajes . . . 9
2.6.2. Suplantación de identidad . . . 13
2.6.3. Modificación del tráfico y las tablas de enrutamiento . . . 23

3. Ataques web **23**
3.1. Inyección de código SQL . . . 23
3.2. Cross-Site Scripting (XSS) . . . 25
3.3. Otros tipos de ataques web . . . 27
3.4. Nikto . . . 28

4. Ataques a contraseñas. Fases de registro y autenticación **29**
4.1. Fuerza bruta y ataques de diccionario . . . 29
4.2. Ingeniería social y keylogger . . . 31
4.3. Factores de autenticación . . . 31
4.4. Fases de registro y autenticación . . . 31
4.5. Rainbow Tables . . . 33
4.6. Herramientas de cracking de contraseñas . . . 34

5. Seguridad en la conexión con redes públicas **35**
5.1. Identificación digital . . . 35
5.2. Firma electrónica y certificado digital . . . 36
5.3. Infraestructura de clave pública (PKI) . . . 37
5.4. Revocación y ciclo de vida de los certificados . . . 38

5.5. Conexiones SSH . . . 38
5.6. Redes privadas virtuales (VPN) . . . 39
5.7. HTTPS y seguridad en la navegación web . . . 39
5.8. Seguridad de las conexiones inalámbricas . . . 40
5.9. Riesgos de las redes Wi-Fi públicas . . . 41

6. Seguridad en la red corporativa **41**
6.1. Monitorización del tráfico en redes . . . 42
6.1.1. Herramientas de captura y análisis del tráfico . . . 42
6.1.2. Filtros de captura y filtros de visualización . . . 43
6.1.3. Herramientas de monitorización de redes y equipos . . . 43
6.2. Detección de intrusos . . . 44
6.2.1. Métodos de detección . . . 44
6.2.2. Tipos de sistemas de detección . . . 44
6.2.3. Sistemas de prevención de intrusos . . . 45
6.3. Comunicaciones inalámbricas . . . 45
6.3.1. Estándares IEEE 802.11 . . . 46
6.3.2. Seguridad de las comunicaciones inalámbricas . . . 46
6.3.3. Filtrado de direcciones MAC y ocultación del SSID . . . 47
6.3.4. Mecanismos de cifrado: WEP, WPA, WPA2 y WPA3 . . . 47
6.3.5. Ataques mediante puntos de acceso falsos . . . 48
6.3.6. Servidores de autenticación y WPA-Enterprise . . . 48
6.3.7. Servidor RADIUS . . . 49
6.3.8. Portal cautivo . . . 49

1. Elaboración de un manual de seguridad y planes de contingencia

El objetivo de un **manual de seguridad** es establecer los estándares y normas que deben seguir las personas de una organización para reducir los problemas de seguridad y determinar cómo se debe actuar ante diferentes situaciones. Los **planes de contingencia**, por su parte, tienen como finalidad recuperar el funcionamiento de la organización cuando se produce un desastre o una incidencia grave.

El manual debe adaptarse a la filosofía de la organización y al nivel de conocimientos de los profesionales que la integran. La elaboración debe contar con representación de diferentes departamentos para que se tengan en cuenta los distintos perfiles y necesidades de la organización.

Como mínimo, el proceso de elaboración comprende:

1. formar un equipo con personas de diferentes departamentos;
2. elaborar el documento teniendo en cuenta los factores humanos y tecnológicos, la legislación vigente, las responsabilidades de los usuarios y los criterios de actuación;
3. aprobar y publicar oficialmente el manual, comunicándolo a todos los usuarios y dejando constancia de que ha sido recibido.

1.1. Plan de contingencias

El **plan de contingencias** está orientado a recuperar el funcionamiento normal del sistema después de una incidencia. Debe partir de un análisis de riesgos y de un estudio de las medidas de protección disponibles.



Figura 1: Plan de contingencias.

El análisis de riesgos debe responder, como mínimo, a cuatro cuestiones:

1. ¿Qué se debe proteger?
2. ¿Qué puede ir mal?
3. ¿Con qué frecuencia puede ocurrir?
4. ¿Cuáles pueden ser las consecuencias?

El estudio de las protecciones existentes debe identificar las medidas implantadas y comprobar que funcionan correctamente. A partir de esta información se diseña el procedimiento de recuperación, que debe indicar con claridad el origen del fallo, el daño ocasionado y las actuaciones que deben realizarse.

El plan de recuperación puede dividirse en tres fases:

Plan de respaldo (antes)
: Medidas preparadas previamente para disponer de recursos que permitan responder a una incidencia. Incluye, entre otras actuaciones, mecanismos de copia y procedimientos previstos.

Plan de emergencia (durante)
: Actuaciones que deben ejecutarse mientras se está produciendo el incidente para controlar la situación y evitar que el daño aumente.

Plan de recuperación (después)
: Procedimientos destinados a restaurar el funcionamiento normal una vez controlado el incidente.

> Idea clave
>
> Un plan de contingencias no consiste únicamente en tener copias de seguridad. Debe contemplar los riesgos, las protecciones existentes y los procedimientos que deben aplicarse antes, durante y después de una incidencia.

1.2. Pautas y prácticas seguras

Un sistema informático no es seguro únicamente por disponer de herramientas de protección: también debe utilizarse de forma segura. Las prácticas de los usuarios y administradores forman parte de la seguridad del sistema.

Entre las pautas de seguridad más importantes se encuentran:

- mantener actualizado el sistema operativo y las aplicaciones;
- descargar software y actualizaciones desde sitios de confianza;
- analizar periódicamente los sistemas para detectar software malicioso;
- utilizar contraseñas robustas y una política adecuada de contraseñas;
- utilizar certificados digitales cuando sean necesarios;
- comunicar las incidencias de seguridad;
- realizar copias de seguridad.

También deben evitarse determinadas creencias erróneas. El software de seguridad no garantiza una protección absoluta y debe mantenerse actualizado. Del mismo modo, no debe suponerse que un equipo carece de valor para un atacante simplemente porque el usuario no considere importantes los datos que contiene. Los ataques no se limitan a grandes organizaciones: la automatización permite que pequeñas intrusiones puedan repetirse a gran escala.

1.2.1. Herramientas preventivas y paliativas

Las **herramientas preventivas** tienen como finalidad evitar que un sistema sea atacado y proteger los principios de confidencialidad, integridad, disponibilidad, autenticación y no repudio. Entre las medidas citadas se encuentran el antimalware, los cortafuegos, el cifrado de las comunicaciones, los sistemas de detección de intrusos, los mecanismos de autenticación, los sistemas tolerantes a fallos, la protección física, la climatización y los sistemas de alimentación ininterrumpida.

Las **herramientas paliativas** buscan reducir el impacto producido por un ataque o una incidencia. Una misma medida puede desempeñar ambas funciones. Las copias de seguridad son un ejemplo claro de medida paliativa, ya que permiten restaurar información después de una pérdida, aunque también constituyen una medida preventiva frente a consecuencias irreversibles.



Figura 2: CD en llamas.

Los sistemas **RAID** utilizan varias unidades de almacenamiento para distribuir o replicar datos y mejorar la tolerancia frente a fallos de los discos. Además, la disponibilidad puede reforzarse mediante servicios de **Cloud Computing**, donde determinados proveedores ofrecen infraestructuras accesibles a través de Internet y con características de rapidez y escalabilidad.

1.2.2. Actualización de sistemas y aplicaciones



Figura 3: Sistemas operativos.

La actualización de sistemas y aplicaciones es una de las medidas preventivas y paliativas más importantes. Los sistemas presentan fallos de seguridad y, con la aparición de nuevas aplicaciones y técnicas, pueden surgir nuevas vulnerabilidades. Por ello, el software debe mantenerse actualizado a medida que aparecen nuevas necesidades.

Las actualizaciones tienen principalmente dos objetivos:

- corregir fallos detectados;
- incorporar nuevas funcionalidades y mejoras.

Las actualizaciones pueden mejorar también la seguridad y el funcionamiento del sistema. En algunos casos se ofrece la posibilidad de seleccionar qué actualización instalar para reducir problemas de incompatibilidad con las aplicaciones o el hardware.

Secunia PSI fue una herramienta de utilidad gratuita para Windows que se encargaba de examinar un sistema en busca de actualizaciones del software instalado, para avisar de posibles actualizaciones y mejoras. Una vez el sistema fuese examinado, mostraba al software clasificado en tres categorías: actualizado, no actualizado e inseguro. En los casos donde se puedan realizar mejoras serían mostrados enlaces de descarga de las aplicaciones que deben actualizarse. Sin embargo, el programa fue descontinuado definitivamente el 20 de abril de 2018. Tras su cierre por parte de Flexera (la empresa que adquirió Secunia), los servidores que daban soporte a la base de datos de firmas de software dejaron de funcionar, por lo que la aplicación ya no es operativa.

2. Ataques y contramedidas en sistemas personales

La seguridad informática puede clasificarse atendiendo a distintos criterios. Desde el punto de vista de los activos afectados se habla de **seguridad física** y **seguridad lógica**; atendiendo al momento de actuación se distingue entre **seguridad activa** y **seguridad pasiva**.

La seguridad física protege los elementos materiales del sistema, mientras que la seguridad lógica se ocupa del software, los datos, las comunicaciones y los mecanismos de acceso. La seguridad activa pretende **evitar o prevenir daños**; la seguridad pasiva pretende **minimizar sus consecuencias y facilitar la recuperación**.

Un **ataque informático** puede entenderse como la materialización de una amenaza aprovechando una vulnerabilidad de alguno de los activos del sistema: hardware, software, datos o personas. Las medidas utilizadas para anular o minimizar el impacto de los ataques reciben el nombre de **contramedidas**.



Figura 4: Malware.

2.1. Anatomía de un ataque y análisis de software malicioso

Comprender cómo se estructura un ataque permite identificar puntos en los que introducir medidas defensivas. Un ataque informático suele desarrollarse mediante cinco fases habituales:

1. **Reconocimiento:** recopilación de información sobre el objetivo. Se utilizan técnicas como ingeniería social y búsqueda de información pública o *footprinting*.
2. **Exploración:** escaneo del sistema para localizar direcciones IP, nombres DNS, puertos abiertos, servicios y versiones. Pueden intervenir herramientas de análisis de tráfico y escaneo de puertos.
3. **Acceso:** aprovechamiento de una vulnerabilidad, credenciales obtenidas o algún recurso no autorizado para entrar en el sistema o provocar un ataque.
4. **Mantenimiento del acceso:** búsqueda de mecanismos que permitan repetir el acceso, por ejemplo mediante privilegios modificados, puertas traseras o determinados programas maliciosos.
5. **Borrado de huellas:** eliminación o modificación de rastros de la actividad realizada, como ficheros de registro o alarmas.

El análisis de malware puede realizarse mediante técnicas estáticas y dinámicas. El análisis estático estudia el programa sin ejecutarlo; el análisis dinámico ejecuta el software en un entorno controlado para observar procesos, cambios, conexiones y comunicaciones. Para el segundo enfoque son habituales los entornos aislados (sandbox) o máquinas virtuales.

2.2. Clasificación de los ataques

Los ataques pueden clasificarse en:

Activos Producen cambios en el sistema o en la información. Buscan modificar el funcionamiento normal, introducir información, alterar datos o impedir un servicio.

Pasivos No producen modificaciones. Se limitan principalmente a obtener información y, en muchos casos, la víctima no percibe que se ha producido el ataque.

Entre las principales categorías de ataques se encuentran el reconocimiento de sistemas, la explotación de vulnerabilidades, el robo de información por interceptación, la suplantación de identidad, la modificación del tráfico y de las tablas de enrutamiento, los ataques de tipo Cross-Site Scripting, la inyección de código SQL y los ataques contra usuarios y contraseñas.

2.3. Footprinting o Information Gathering

El **footprinting** consiste en recopilar información pública sobre una organización o sistema que se pretende auditar. Se buscan datos como direcciones IP, servidores, cuentas de correo,

nombres de máquinas, datos del registrador del dominio, tipos de servidores, metadatos y otros elementos que puedan resultar útiles para etapas posteriores de una auditoría.

En el contexto de un **pentest** (Penetration Test), una secuencia general de trabajo puede organizarse en cinco etapas:

1. **Footprinting:** consiste en recopilar información sobre el objetivo, como dominios, direcciones IP, sistemas, servicios, tecnologías utilizadas y cualquier otro dato que pueda resultar útil durante las fases posteriores.

2. **Fingerprinting:** permite identificar con mayor precisión los sistemas y servicios encontrados, determinando aspectos como el sistema operativo, las versiones del software, los servicios activos y las tecnologías empleadas.

3. **Análisis de vulnerabilidades:** se estudia la información obtenida para localizar posibles debilidades de seguridad, configuraciones incorrectas, servicios vulnerables o versiones de software que puedan ser explotadas.

4. **Explotación de vulnerabilidades:** se comprueba de forma controlada si las vulnerabilidades identificadas pueden ser aprovechadas para obtener acceso, elevar privilegios o demostrar el impacto que tendría una explotación real.

5. **Generación de informes:** se documentan los resultados obtenidos, incluyendo las vulnerabilidades detectadas, las evidencias recopiladas, el impacto potencial y las recomendaciones necesarias para corregir o mitigar los problemas encontrados.

La recopilación puede apoyarse en la web pública, buscadores, información de DNS, servidores de correo, dominios y subdominios, servicios de consulta de dominios e información publicada en Internet. El objetivo del footprinting es obtener información sin interactuar directamente con el sistema objetivo cuando se trabaja desde una perspectiva pasiva.

2.3.1. OSINT y Maltego

La metodología **OSINT** (*Open Source Intelligence*) agrupa técnicas y herramientas destinadas a recopilar, correlacionar y procesar información pública.

Maltego es una herramienta de minería de datos interactiva orientada al análisis de relaciones. Representa gráficamente conexiones entre entidades como personas, alias, direcciones de correo, dominios, perfiles sociales, dispositivos y datos de geolocalización. Para ello utiliza *transforms*, pequeñas aplicaciones que realizan tareas concretas sobre las entidades seleccionadas.

2.3.2. Google Hacking y Bing Hacking

El llamado **Google Hacking** consiste en emplear operadores avanzados de búsqueda, conocidos como *dorks*, para localizar información pública indexada por los buscadores. Entre los operadores más frecuentes se encuentran `site`, `intitle`, `allintitle`, `intext`, `inurl`, `filetype`, `related`, `cache` e `info`.

Los operadores avanzados de búsqueda permiten localizar documentos o ficheros que cumplen determinados criterios. Desde el punto de vista del reconocimiento, el proceso se basa en información que ya está publicada e indexada, sin necesidad de interactuar directamente con el servidor auditado.

Bing dispone de operadores semejantes. Entre los operadores disponibles se encuentran `ext`, `ip` y `location`, que permiten restringir la búsqueda por extensión, dirección IP o localización.

2.3.3. Shodan

Shodan es un buscador especializado en dispositivos y servicios conectados a Internet. A diferencia de los buscadores de contenido web, no se centra en indexar las páginas de los sitios, sino en recopilar información obtenida de los *banners* de los servicios.

Esto permite localizar determinados servidores, routers y otros dispositivos y conocer información relacionada con tecnologías, servicios, versiones o configuraciones expuestas. **Censys** es un servicio similar orientado al análisis de dispositivos y sistemas accesibles desde Internet.

Entre los operadores de Shodan aparecen `country`, `city`, `hostname`, `net`, `os`, `port`, `before` y `after`, útiles para restringir los resultados de las búsquedas.

2.4. Fingerprinting

El **fingerprinting** consiste en recopilar información interactuando directamente con los sistemas que se están auditando. Una de las técnicas principales es el escaneo de puertos para identificar puertos abiertos y determinar qué servicios y versiones existen detrás de ellos.

A diferencia del footprinting, el fingerprinting implica interacción con el sistema objetivo y puede proporcionar información más precisa sobre su configuración y comportamiento. Además del escaneo de puertos, herramientas de consulta como **WHOIS** permiten obtener datos asociados a dominios o direcciones IP.

2.5. Explotación de vulnerabilidades

Una vez identificada una vulnerabilidad, puede existir un programa específicamente diseñado para aprovecharla. Estos programas se denominan **exploits**. Los exploits pueden permitir que el sistema atacado realice acciones no previstas y existen repositorios y frameworks que facilitan su utilización durante auditorías autorizadas.

Metasploit es un framework de código abierto utilizado principalmente para realizar pruebas de intrusión. Proporciona información sobre vulnerabilidades y automatiza la selección, configuración y ejecución de componentes relacionados con un test de seguridad.

La estructura del framework se organiza alrededor de **interfaces, módulos y librerías**. Entre las interfaces aparecen `msfconsole`, `msfcli`, interfaces web y gráficas y Armitage.

Los módulos constituyen el núcleo funcional del framework:

- **Auxiliary:** acciones adicionales como escaneos, sniffing o pruebas de fuerza bruta.
- **Encoders:** transforman el contenido asociado a un payload con el objetivo de evitar determinadas detecciones.
- **Post modules:** acciones de post-explotación, como la enumeración de información del sistema comprometido.
- **Payloads:** código que se ejecuta en el sistema objetivo después de aprovechar una vulnerabilidad.
- **Exploits:** componentes que implementan la explotación de vulnerabilidades concretas.

Los módulos de exploit se organizan según su finalidad y pueden trabajar con conexiones directas o *bind* y conexiones inversas o *reverse*. Los **workspaces** permiten separar y organizar los datos de diferentes trabajos de auditoría.

2.6. Ataques según el principio de seguridad vulnerado

Los ataques también pueden clasificarse según el principio básico de seguridad que se ve afectado. Pueden distinguirse cuatro categorías principales:

Intercepción Ataque pasivo relacionado con la **confidencialidad**. El intruso accede a información transmitida sin modificarla.

Interrupción Ataque activo relacionado con la **disponibilidad**. Un recurso del sistema o de la red deja de poder utilizarse. El ejemplo típico es la denegación de servicio (DoS).

Modificación Ataque activo que afecta a la información durante su recorrido entre emisor y receptor. Se relaciona con la alteración de datos y puede afectar a la **confidencialidad e integridad**. Un ejemplo de este tipo de ataque es el ARP spoofing.

Fabricación Ataque activo asociado a la **autenticación**. Se introducen datos o comunicaciones que pretenden parecer legítimos. El ejemplo utilizado es el **phishing**.

2.6.1. Interceptación de mensajes

La **interceptación de mensajes** es un tipo de ataque cuyo objetivo principal es obtener información que está siendo transmitida entre dos dispositivos. En una red pública como Internet, resulta difícil impedir completamente que un atacante pueda capturar determinados datos que circulan por la red. Sin embargo, sí es posible dificultar que la información interceptada pueda ser interpretada.

Una de las principales medidas de protección consiste en utilizar mecanismos de **cifrado** que permitan proteger el contenido de las comunicaciones. Entre las soluciones utilizadas para proteger los mensajes de correo electrónico destacan **PGP** y **S/MIME**.

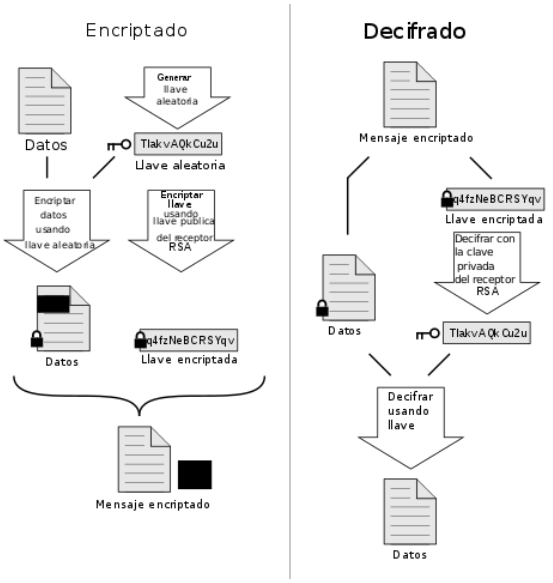


Figura 5: Protección de mensajes mediante PGP y S/MIME.

1. **S/MIME (Secure/Multipurpose Internet Mail Extensions):** utiliza criptografía de clave pública para proporcionar seguridad en los mensajes de correo electrónico. Sus principales funciones son:

   a) **Cifrado del contenido:** permite proteger el contenido del mensaje de correo electrónico para impedir que pueda ser interpretado por terceros. Los encabezados del mensaje no quedan protegidos mediante este mecanismo.

   b) **Firma digital:** permite firmar electrónicamente los mensajes para garantizar la autenticidad del remitente y detectar posibles modificaciones del contenido.

2. **PGP (Pretty Good Privacy):** también utiliza criptografía de clave pública y está orientado principalmente a:

   a) **Proteger la información:** permite cifrar información que se distribuye a través de Internet.

   b) **Autenticar documentos:** permite utilizar firmas digitales para comprobar la identidad del emisor y la integridad de la información.

Para utilizar estos mecanismos de criptografía de clave pública, tanto el emisor como el receptor disponen de un par de claves:

- **Clave pública:** puede ser compartida con otras personas y se utiliza en las operaciones criptográficas destinadas a proteger o verificar la información.
- **Clave privada:** debe mantenerse en secreto y únicamente debe estar en posesión de su propietario. Se utiliza junto con la clave pública correspondiente para realizar las operaciones de cifrado, descifrado y firma digital, según el mecanismo empleado.

Sniffing Para capturar los paquetes que circulan entre un emisor y un receptor, un atacante puede utilizar una técnica conocida como **sniffing**. Esta técnica consiste en analizar el tráfico de red para localizar información que pueda resultar de interés.

Para realizar esta tarea se utilizan programas denominados **sniffers**, que se encargan de capturar y analizar los paquetes que circulan por la red.

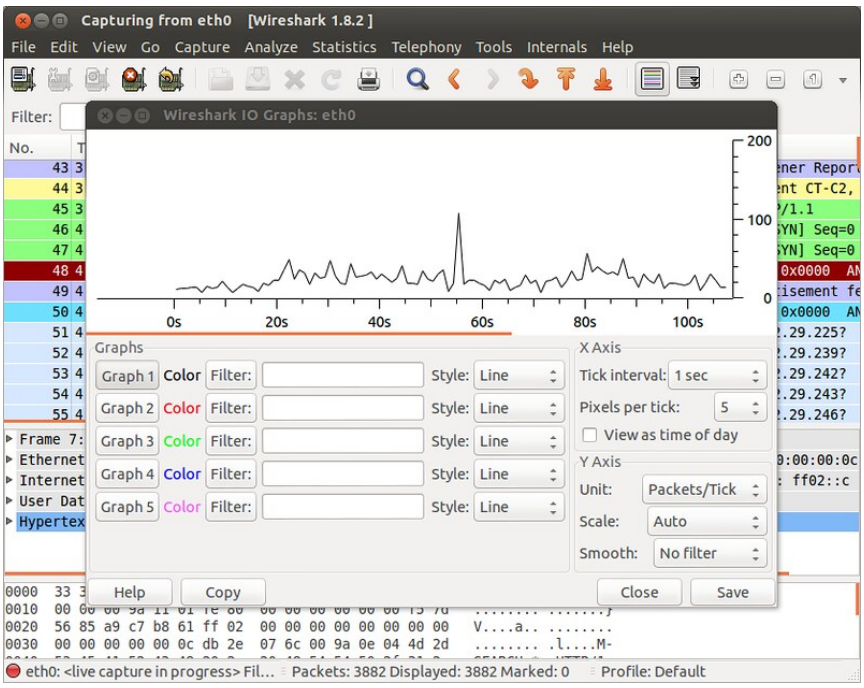


Figura 6: Captura y análisis de tráfico de red mediante Wireshark.

El sniffing se caracteriza por los siguientes aspectos:

1. El atacante **captura los paquetes** que circulan por la red.
2. Los paquetes son **analizados en busca de información** que pueda resultar útil.
3. El atacante **no modifica el flujo de datos** durante la captura.

4. Por tanto, se considera un **ataque de intercepción**, ya que el objetivo es obtener información sin alterar las comunicaciones.

Para facilitar la captura del tráfico, el sniffer puede configurar la tarjeta de red en **modo promiscuo**. En este modo, la tarjeta de red procesa las tramas que recibe aunque no estén dirigidas específicamente a su dirección MAC.

De esta forma, en la **capa de enlace de datos**, las tramas que normalmente serían descartadas por no estar destinadas a la dirección MAC de la tarjeta pueden ser capturadas y analizadas.

El funcionamiento del sniffing presenta diferencias dependiendo de si la red es **cableada** o **inalámbrica**.

Sniffing en LAN cableadas En una red cableada basada en **switches**, la captura de tráfico resulta más complicada que en una red basada en concentradores (*hubs*). El switch mantiene una tabla de direcciones MAC que le permite determinar por qué puerto debe reenviar cada trama.

Por tanto:

1. El switch recibe una trama.
2. Consulta la dirección MAC de destino.
3. Busca dicha dirección en su tabla de direcciones MAC.
4. Reenvía la trama únicamente por el puerto asociado al dispositivo destinatario.

Esto impide que, en condiciones normales, un atacante conectado a otro puerto pueda observar todo el tráfico de la red.

MAC flooding Una técnica que puede utilizarse para intentar superar esta limitación es el **MAC flooding**. Consiste en generar un gran número de tramas utilizando diferentes direcciones MAC de origen con el objetivo de saturar la memoria destinada a almacenar la tabla de direcciones MAC del switch.

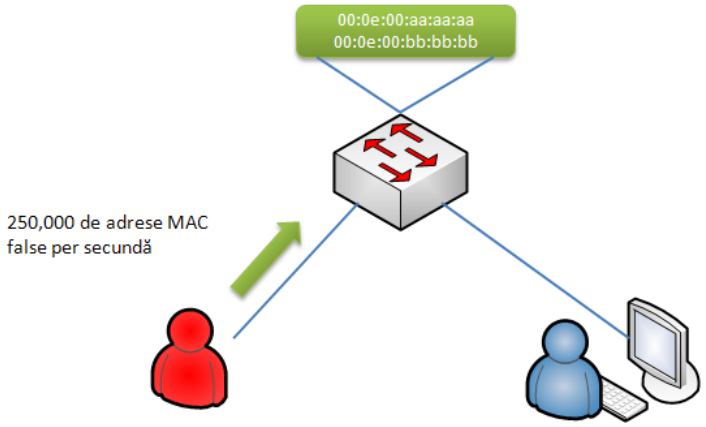


Figura 7: Ejemplo de ataque basado en MAC flooding.

De forma simplificada, el proceso puede describirse en los siguientes pasos:

1. El atacante genera un gran número de tramas con diferentes direcciones MAC de origen.
2. El switch intenta almacenar estas direcciones en su tabla MAC.

3. Si la tabla alcanza su capacidad, el switch puede dejar de aprender nuevas direcciones.

4. Dependiendo del comportamiento y configuración del dispositivo, parte del tráfico puede comenzar a reenviarse por múltiples puertos.

5. Esto puede facilitar que un atacante conectado a la red capture tráfico que originalmente no estaba destinado a su dispositivo.

Medidas de protección frente al MAC flooding Existen diferentes mecanismos que permiten reducir el riesgo de este tipo de ataques.

1. **Port Security:** permite controlar las direcciones MAC que pueden utilizarse a través de una determinada interfaz del switch.

   a) **Aprendizaje automático:** el switch aprende las direcciones MAC recibidas por la interfaz hasta alcanzar el número máximo configurado. Si se supera dicho límite, se produce una violación de seguridad y se ejecuta la acción configurada, como deshabilitar la interfaz.
   b) **Configuración manual:** el administrador especifica las direcciones MAC que están autorizadas a utilizar la interfaz. Cuando se recibe una trama, el switch compara la dirección MAC de origen con las direcciones permitidas. Si no existe coincidencia, se considera una violación de seguridad y se aplica la acción configurada.

   Las dos modalidades proporcionan diferentes niveles de protección:

   - El aprendizaje automático permite limitar el número de direcciones MAC que pueden aparecer en una interfaz y dificulta el envío masivo de direcciones.
   - La configuración manual, además de limitar el número de direcciones, permite impedir que dispositivos no autorizados utilicen direcciones MAC diferentes para acceder a la red.

2. **Protocolo 802.1X:** permite realizar un proceso de autenticación entre un dispositivo y la infraestructura de red antes de conceder acceso.

   a) El dispositivo solicita acceso a la red.
   b) Se inicia un proceso de autenticación entre el dispositivo y el switch.
   c) Si la autenticación es correcta, se permite el acceso a la red.
   d) Si la autenticación falla, el acceso es denegado.

   De esta forma, el protocolo 802.1X permite controlar qué dispositivos pueden acceder a la red y dificulta ataques basados en el envío masivo o la falsificación de direcciones MAC.

3. **Asignación estática de direcciones MAC:** consiste en asociar de forma manual determinadas direcciones MAC con puertos concretos del switch. De este modo, se limita qué dispositivos pueden utilizar cada interfaz.

Sniffing en LAN inalámbricas En las redes inalámbricas, la naturaleza de las comunicaciones hace posible que las señales de radio puedan ser capturadas por dispositivos situados dentro de su alcance.

Sin embargo, **capturar una comunicación no implica necesariamente poder interpretarla**. Las redes Wi-Fi utilizan mecanismos de cifrado para proteger las comunicaciones. Por tanto, si el cifrado utilizado es seguro y está correctamente configurado, la información capturada no podrá interpretarse directamente.

De forma general:

1. El dispositivo atacante captura las señales inalámbricas que se encuentran dentro de su alcance.
2. El sniffer analiza las tramas capturadas.
3. Si las comunicaciones están correctamente cifradas, el contenido permanece protegido.
4. Si se consigue romper o comprometer el mecanismo de seguridad utilizado, el atacante podría acceder al contenido de las comunicaciones.

Detección de interfaces en modo promiscuo Una posible medida de detección consiste en intentar identificar si alguno de los dispositivos de la red está utilizando su adaptador de red en **modo promiscuo**.

Para ello existen herramientas que envían determinados paquetes que normalmente no deberían provocar una respuesta. Un dispositivo que esté funcionando en modo promiscuo puede procesarlos y responder, proporcionando una indicación de que podría estar capturando tráfico.

Entre las técnicas de detección se encuentran las siguientes:

1. **Detección mediante latencia de paquetes ICMP:**

   Se generan paquetes que normalmente no deberían ser procesados por los dispositivos de la red. Posteriormente se realizan peticiones `ping` a los equipos sospechosos. Un equipo que esté utilizando el modo promiscuo puede presentar una mayor latencia al tener que procesar también los paquetes que normalmente descartaría.

2. **Detección mediante paquetes ICMP con dirección MAC falsa:**

   Se envía una petición `ping` dirigida a un equipo utilizando una dirección MAC de destino que no corresponde con dicho dispositivo. En determinadas circunstancias, un equipo configurado en modo promiscuo puede procesar la trama y responder, proporcionando una posible indicación de que su interfaz está configurada en dicho modo.

3. **Detección mediante paquetes ARP:**

   Se envía una petición ARP dirigida a la dirección IP del equipo sospechoso, utilizando una dirección MAC inexistente o no correspondiente. Si el dispositivo procesa y responde a la petición, puede existir una indicación de que su interfaz está funcionando en modo promiscuo.

   Este procedimiento puede repetirse para las diferentes direcciones IP válidas del rango de red local con el objetivo de comprobar los distintos dispositivos conectados.

2.6.2. Suplantación de identidad

La **suplantación de identidad**, también conocida como **Spoofing**, es un tipo de ataque en el que el atacante intenta hacerse pasar por otro dispositivo, usuario o servicio legítimo para obtener información, interceptar comunicaciones o acceder a recursos.

Entre las principales técnicas de suplantación se encuentran:

- **ARP Spoofing:** se enmascaran o falsifican las asociaciones entre direcciones IP y direcciones MAC.
- **IP Spoofing:** se falsifica la dirección IP de origen de los paquetes de red.
- **DNS Spoofing:** se proporciona una traducción falsa de nombres de dominio a direcciones IP.
- **SMTP Spoofing:** se envían mensajes de correo electrónico utilizando remitentes falsificados.
- **Captura de credenciales:** se emplean técnicas de suplantación para obtener nombres de usuario o contraseñas.

ARP Spoofing El **ARP Spoofing** es una técnica de suplantación que consiste en engañar a la tabla ARP que los equipos mantienen en memoria. Esta tabla establece una asociación entre la dirección IP de un dispositivo y la dirección física o **MAC** de su tarjeta de red.

El objetivo del ataque es conseguir que el equipo de la víctima crea que la dirección MAC de otro dispositivo de la red corresponde realmente a la del atacante. De esta forma, el atacante puede situarse en medio de la comunicación y conseguir que el tráfico entre los dos equipos afectados pase por su dispositivo.

El funcionamiento general del ataque puede resumirse en los siguientes pasos:

1. El atacante identifica los dispositivos que intervienen en la comunicación, por ejemplo, la máquina víctima y la puerta de enlace de la red.
2. El atacante envía mensajes ARP manipulados para modificar las asociaciones almacenadas en las tablas ARP de los dispositivos.
3. La víctima pasa a asociar la dirección IP de la puerta de enlace con la dirección MAC del atacante.
4. Como consecuencia, el tráfico que la víctima dirige hacia la puerta de enlace es enviado inicialmente al equipo del atacante.
5. El atacante puede analizar el tráfico interceptado y, dependiendo de la finalidad del ataque, reenviarlo hacia su destino original.

Una vez situado entre los dos extremos de la comunicación, el atacante puede actuar de dos formas:

- **Ataque pasivo:** el atacante reenvía el tráfico hacia el equipo legítimo sin modificarlo, limitándose a escuchar y analizar las comunicaciones. Esta situación se encuentra relacionada con los ataques de tipo **Man-in-the-Middle (MitM)**.
- **Ataque activo:** el atacante modifica los datos interceptados antes de reenviarlos al destinatario.

Idea clave

El ARP Spoofing aprovecha la ausencia de mecanismos de autenticación en el protocolo ARP para manipular las asociaciones entre direcciones IP y MAC. De esta forma, un atacante puede situarse en medio de una comunicación y analizar o modificar el tráfico que circula entre los dispositivos afectados.

IP Spoofing El **IP Spoofing** es una técnica de suplantación mediante la cual el atacante modifica la dirección IP de origen de un paquete para hacer creer al equipo destinatario que el paquete procede de otro dispositivo.

El objetivo principal es, por tanto, **ocultar o falsificar la identidad del emisor**. Para ello, se sustituye la dirección IP de origen de un paquete TCP/IP por otra dirección IP que pertenece al dispositivo que se desea suplantar.

Esta técnica puede utilizarse con diferentes protocolos de la pila TCP/IP, entre ellos:

- **TCP**.
- **UDP**.
- **ICMP**.

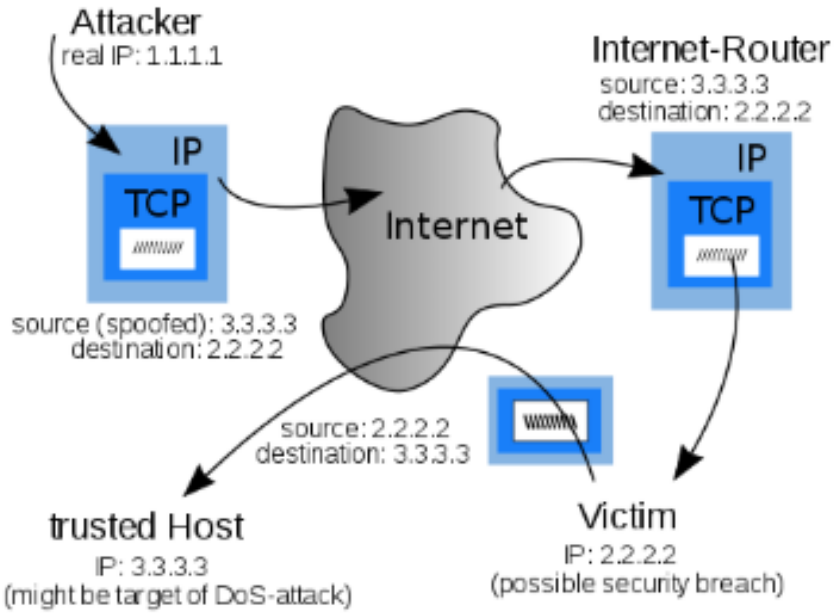


Figura 8: Funcionamiento de un ataque IP Spoofing.

¿Qué ocurre con las respuestas?

Una característica importante del IP Spoofing es que las respuestas generadas por el equipo destinatario se envían a la dirección IP que el atacante ha falsificado. Por tanto, **las respuestas no llegan directamente al atacante**.

Además, existen algunas limitaciones que dificultan este tipo de ataque:

1. El equipo cuya dirección IP se está suplantando puede detectar que está recibiendo paquetes que no ha solicitado y cortar la comunicación.

2. Los routers actuales suelen aplicar mecanismos de filtrado que impiden el envío de paquetes cuya dirección IP de origen no pertenece a alguna de las redes que administran.

A pesar de estas limitaciones, el IP Spoofing puede resultar especialmente peligroso cuando el atacante y la víctima se encuentran en la misma red local.

Para que este escenario sea posible, deben cumplirse principalmente las siguientes condiciones:

1. El equipo destinatario del paquete falsificado debe encontrarse en la misma red local que el atacante.

2. La dirección IP utilizada para la suplantación no debe estar siendo utilizada por otro dispositivo de la red.

De esta forma, se evita que el paquete tenga que atravesar un router que pueda descartarlo y se reduce la posibilidad de que el dispositivo cuya dirección IP se ha suplantado interfiera en la comunicación.

IP Spoofing y ataques DoS El IP Spoofing también puede utilizarse como parte de un ataque de **Denegación de Servicio (DoS)**.

Una posibilidad consiste en enviar una gran cantidad de paquetes hacia la víctima utilizando como dirección IP de origen la de otro dispositivo. La víctima responderá a cada uno de los

paquetes recibidos, pero las respuestas serán enviadas hacia la dirección falsificada y no hacia el atacante.

De esta manera, la víctima puede mantener numerosas comunicaciones abiertas esperando respuestas que nunca llegarán, consumiendo recursos del sistema.

Idea clave

El IP Spoofing no permite, por sí solo, recibir las respuestas dirigidas a la dirección IP falsificada. Precisamente por ello, una de sus aplicaciones es generar tráfico hacia una víctima haciendo que las respuestas sean dirigidas hacia otro equipo.

Mitigación del IP Spoofing Las principales medidas de protección frente al IP Spoofing se basan en **filtrar el tráfico** y en **verificar el origen de los dispositivos**.

1. **Filtros anti-spoofing en routers.**

   Los routers pueden configurarse para descartar paquetes cuya dirección IP de origen no sea coherente con la red desde la que se reciben.

   Entre las reglas que pueden establecerse se encuentran:

   - Filtrar los paquetes salientes cuya IP de origen no pertenezca a alguna de las redes gestionadas por el router.
   - Filtrar los paquetes entrantes cuya IP de origen pertenezca a alguna de las redes gestionadas por el propio router.

2. **Autenticación de los equipos.**

   Otra posibilidad consiste en utilizar mecanismos de autenticación que permitan comprobar el origen de los paquetes. El material de referencia señala que **IPv6** incorpora mecanismos que permiten mejorar esta verificación y dificultar este tipo de ataques.

DHCP Snooping e IP Source Guard Los filtros anti-spoofing de los routers no resultan suficientes cuando el atacante y la víctima se encuentran dentro de la misma LAN.

En este escenario puede utilizarse una combinación de mecanismos de seguridad en el switch:

1. El switch examina la cabecera IP del paquete para obtener la dirección IP de origen.
2. También comprueba la dirección MAC de origen de la trama Ethernet.
3. El switch compara ambas informaciones con las asociaciones conocidas en su tabla de direcciones.
4. Si la correspondencia entre la dirección IP y la dirección MAC no es válida, el paquete puede ser descartado.
5. Dependiendo de la configuración, el switch puede incluso bloquear el puerto desde el que se ha detectado la anomalía.

Para realizar esta comprobación se puede utilizar **DHCP Snooping**. Sobre esta información puede aplicarse **IP Source Guard**, que permite impedir que un dispositivo utilice una dirección IP distinta de la que tiene asociada.

Protección frente a IP Spoofing

DHCP Snooping permite al switch conocer las asociaciones válidas entre dispositivos y parámetros de red, mientras que **IP Source Guard** puede utilizar esta información para bloquear tráfico con direcciones IP de origen no autorizadas.

DNS Spoofing El **DNS Spoofing** engloba diferentes técnicas cuyo objetivo es manipular la información proporcionada por los servidores DNS.

El objetivo del atacante es conseguir que una consulta DNS devuelva una dirección IP diferente de la que corresponde realmente al dominio solicitado.

Entre las técnicas relacionadas con este tipo de ataque se encuentran:

- **DNS Cache Poisoning**: manipulación de la información almacenada en las cachés DNS.
- **Man-in-the-Middle (MitM)**: interceptación de las comunicaciones para modificar las respuestas DNS.
- **DNS Hijacking**: modificación o redirección de las consultas DNS hacia servidores controlados por el atacante.

Por ejemplo, cuando un usuario solicita acceder a un determinado sitio web, el equipo necesita conocer la dirección IP asociada al nombre de dominio. Si la respuesta DNS ha sido manipulada, el equipo puede recibir una dirección IP diferente y conectarse a un servidor controlado por el atacante.

Funcionamiento normal de una consulta DNS El funcionamiento normal puede resumirse en tres pasos:

1. **Solicitud DNS:** el equipo cliente solicita al servidor DNS la dirección IP asociada al dominio que desea consultar.
2. **Respuesta DNS:** el servidor DNS responde indicando la dirección IP correspondiente al dominio solicitado.
3. **Conexión con el servidor:** el equipo cliente utiliza la dirección IP obtenida para establecer la conexión con el servidor web.

Ejemplo

Si un usuario solicita acceder a `www.ejemplo.es`, el equipo consulta al servidor DNS cuál es la dirección IP asociada a ese dominio. Una vez recibida la respuesta, el equipo utiliza esa dirección para conectarse al servidor correspondiente.

DNS Spoofing local mediante MitM En un ataque de **DNS Spoofing local**, el atacante puede combinar DNS Spoofing con un ataque **Man-in-the-Middle** para interceptar las consultas DNS de una víctima.

El proceso puede resumirse de la siguiente manera:

1. La víctima solicita la dirección IP correspondiente a un dominio.
2. El atacante, situado en medio de la comunicación, intercepta la petición DNS.
3. En lugar de permitir que la víctima reciba la respuesta legítima, el atacante proporciona una respuesta manipulada.
4. La víctima recibe una dirección IP falsa.
5. El equipo se conecta a un servidor controlado por el atacante, que puede ser una réplica del sitio web original.

Este tipo de ataque puede utilizarse, por ejemplo, para dirigir a una víctima hacia una página web falsa que imita a la original. Si la víctima introduce sus credenciales en ella, estas podrían quedar a disposición del atacante.

> Idea clave
>
> En un DNS Spoofing, la víctima no necesita escribir una dirección web diferente. Puede introducir correctamente el dominio que desea visitar y, sin embargo, terminar conectándose a un servidor diferente debido a que la resolución DNS ha sido manipulada.

Mitigación de DNS Spoofing Una de las principales medidas para proteger las comunicaciones DNS frente a la manipulación es **DNSSEC**.

DNSSEC utiliza mecanismos criptográficos para proporcionar:

- **Autenticidad del origen**: permite comprobar que los datos DNS proceden de una fuente autorizada.
- **Integridad**: permite detectar si la información DNS ha sido modificada durante su transmisión.

> Idea clave
>
> DNSSEC añade mecanismos criptográficos al sistema DNS para comprobar la **autenticidad** y la **integridad** de la información obtenida durante una resolución de nombres.

SMTP Spoofing El **SMTP Spoofing**, también denominado **Email Spoofing**, consiste en falsificar el origen aparente de un correo electrónico.

El objetivo es conseguir que el destinatario crea que el mensaje ha sido enviado por una persona o una organización cuando, en realidad, procede de otro origen.

Un indicio habitual de este tipo de ataque es recibir un mensaje que aparentemente procede de la propia dirección de correo del usuario.

> Importante
>
> No todos los casos en los que alguien parece hacerse pasar por el propietario de una cuenta implican SMTP Spoofing. También puede ocurrir que el atacante haya conseguido acceder directamente a la cuenta de correo o que utilice técnicas de engaño mediante dominios visualmente similares.

Dominios visualmente similares Una técnica relacionada consiste en utilizar direcciones de correo que visualmente se parecen a las legítimas.

Por ejemplo:

- `@google.com` frente a `@google.corn`.
- `@google.com` frente a `@googel.com`.

Aunque las direcciones pueden parecer prácticamente idénticas a simple vista, pertenecen a dominios diferentes.

Por este motivo, es importante comprobar cuidadosamente el dominio del remitente antes de considerar legítimo un mensaje.

Obtención de credenciales La suplantación también puede combinarse con técnicas de **ingeniería social** para obtener información de los usuarios.

Una de las técnicas más conocidas es el **phishing**, mediante el cual el atacante intenta conseguir información como:

- Nombres de usuario.
- Contraseñas.
- Datos bancarios.
- Datos de tarjetas de crédito.

También pueden utilizarse mensajes aparentemente legítimos para distribuir archivos adjuntos maliciosos o dirigir al usuario hacia sitios web fraudulentos.

Mitigación de SMTP Spoofing Los principales mecanismos utilizados para mejorar la autenticidad del correo electrónico son:

1. **SPF (Sender Policy Framework)**
2. **DKIM (DomainKeys Identified Mail)**
3. **DMARC (Domain-based Message Authentication, Reporting and Conformance)**

SPF **SPF** utiliza un registro DNS para indicar qué servidores de correo están autorizados a enviar mensajes en nombre de un determinado dominio.

Cuando se recibe un mensaje, el servidor receptor puede comprobar si el servidor que ha realizado el envío está autorizado para enviar correo en nombre de ese dominio.

SPF en una frase

SPF permite comprobar si el servidor que envía un correo está autorizado para hacerlo en nombre del dominio indicado.

DKIM **DKIM** permite asociar un mensaje de correo con un dominio mediante una firma digital.

Para ello emplea **criptografía de clave pública**. El servidor de correo emisor añade una firma en la cabecera del mensaje y el receptor puede verificarla mediante la clave pública publicada en el DNS.

De esta forma se pueden comprobar principalmente:

- La asociación del mensaje con el dominio.
- La integridad del mensaje durante su transmisión.

DKIM en una frase

DKIM utiliza una firma digital para vincular un mensaje con un dominio y detectar modificaciones realizadas durante su transmisión.

DMARC **DMARC** utiliza la información proporcionada por SPF y DKIM para establecer políticas de autenticación y tratamiento de los mensajes que no superan las comprobaciones.

Entre otras posibilidades, permite establecer qué debe hacer el sistema receptor cuando un mensaje no cumple los mecanismos de autenticación establecidos para el dominio.

SPF + DKIM + DMARC

Los tres mecanismos cumplen funciones relacionadas pero diferentes:

- **SPF**: comprueba si el servidor emisor está autorizado.
- **DKIM**: verifica una firma digital asociada al dominio y la integridad del mensaje.
- **DMARC**: establece políticas para los mensajes que no superan las comprobaciones de autenticación.

DHCP Spoofing El protocolo **DHCP (Dynamic Host Configuration Protocol)** facilita la configuración automática de los dispositivos que se incorporan a una red.

Entre los parámetros que puede proporcionar se encuentran:

- Dirección IP.
- Máscara de subred.
- Puerta de enlace predeterminada.
- Servidor DNS.

El proceso normal de asignación de configuración mediante DHCP se conoce habitualmente como **DORA**:

1. **Discover**: el cliente busca servidores DHCP mediante un mensaje de difusión.
2. **Offer**: un servidor DHCP responde ofreciendo una configuración de red.
3. **Request**: el cliente solicita la configuración ofrecida.
4. **ACK**: el servidor confirma la asignación de los parámetros.

Ataques contra DHCP El funcionamiento de DHCP puede ser aprovechado mediante diferentes ataques. Los dos escenarios principales son:

1. **Servidor DHCP ilegítimo o Rogue DHCP.**
2. **Agotamiento de direcciones o DHCP Starvation.**

Rogue DHCP Un **Rogue DHCP** es un servidor DHCP no autorizado que responde a las solicitudes de configuración de los clientes de la red.

DHCP no proporciona mecanismos de autenticación suficientes para garantizar que todos los mensajes de configuración procedan de un servidor legítimo. Por este motivo, un atacante puede introducir un servidor DHCP no autorizado en la LAN.

Cuando un cliente envía un mensaje **DHCP Discover**, tanto el servidor legítimo como el servidor ilegítimo pueden recibirlo y responder.

Si la respuesta del servidor ilegítimo llega primero, el cliente puede aceptar la configuración proporcionada por el atacante.

Esto puede permitir modificar parámetros especialmente importantes:

- **Puerta de enlace**: se puede establecer como puerta de enlace la dirección IP del atacante, permitiendo interceptar tráfico destinado a otras redes.
- **Servidor DNS**: se puede indicar como servidor DNS el equipo controlado por el atacante, permitiendo manipular las resoluciones de nombres.

Riesgo del Rogue DHCP

Un servidor DHCP ilegítimo puede proporcionar al cliente una configuración aparentemente válida pero controlada por el atacante. Por ello, una modificación aparentemente pequeña, como cambiar la puerta de enlace o el servidor DNS, puede tener consecuencias importantes.

DHCP Starvation El **DHCP Starvation Attack**, o ataque de agotamiento de direcciones DHCP, tiene como objetivo consumir todas las direcciones disponibles en el servidor DHCP.

De forma general, el atacante genera numerosas solicitudes DHCP utilizando diferentes direcciones MAC. El servidor puede interpretar estas solicitudes como si procedieran de dispositivos diferentes y reservar direcciones para ellas.

El ataque puede resumirse en los siguientes pasos:

1. El atacante genera numerosas solicitudes DHCP.
2. Las solicitudes utilizan diferentes direcciones MAC.
3. El servidor DHCP asigna o reserva direcciones para las diferentes solicitudes.
4. El conjunto de direcciones disponibles se va agotando.
5. Cuando un nuevo dispositivo legítimo intenta obtener una dirección IP, el servidor puede no disponer de direcciones libres.

La consecuencia es una **Denegación de Servicio (DoS)** sobre el servicio DHCP de la red.

En algunos escenarios, un atacante puede intentar realizar primero un **DHCP Starvation** para impedir que el servidor DHCP legítimo pueda atender nuevas solicitudes y, posteriormente, introducir un **Rogue DHCP**.

Relación entre ambos ataques

DHCP Starvation busca agotar los recursos del servidor DHCP legítimo, mientras que **Rogue DHCP** busca proporcionar configuraciones de red falsas a los clientes.

Mitigación de DHCP Spoofing La protección frente a ataques relacionados con DHCP puede realizarse mediante diferentes mecanismos de seguridad en los switches.

1. **Port Security**

   Puede configurarse el switch para limitar el número de direcciones MAC permitidas en cada puerto. Una configuración habitual consiste en permitir únicamente una MAC por puerto destinado a un equipo de usuario.

2. **Comprobación de direcciones MAC e IP**

   El switch puede comprobar la coherencia entre la dirección MAC de origen de la trama y la dirección IP de origen indicada en el paquete. Si ambas informaciones no coinciden con las asociaciones conocidas, el tráfico puede ser descartado y el puerto puede llegar a bloquearse.

3. **Listas de control de acceso (ACL)**

   Las ACL pueden utilizarse para impedir que los puertos destinados a usuarios generen tráfico DHCP que no deberían generar, dificultando la instalación de servidores DHCP no autorizados.

4. **DHCP Snooping**

   DHCP Snooping permite definir qué puertos del switch están autorizados para recibir tráfico procedente de servidores DHCP.

   - **Puertos Trusted**: se consideran confiables y pueden recibir o enviar tráfico DHCP procedente de servidores autorizados.
   - **Puertos Untrusted**: no se consideran confiables. El switch puede descartar el tráfico DHCP procedente de estos puertos.

Detección de ataques DHCP Además de las medidas de prevención, es posible utilizar herramientas de análisis para detectar dispositivos o comunicaciones sospechosas.

Una de las posibilidades es utilizar **Wireshark** para analizar las respuestas DHCP y comprobar si los parámetros proporcionados coinciden con los del servidor DHCP legítimo.

Por ejemplo, pueden analizarse las respuestas **DHCP ACK** para detectar:

- Puertas de enlace diferentes de la configurada legítimamente.
- Servidores DNS no autorizados.
- Respuestas procedentes de servidores DHCP desconocidos.

También existen herramientas específicas que permiten localizar servidores DHCP activos dentro de una LAN, como:

- `Globber`.
- `dhcp_probe`.
- `Rogue Detect`.

Resumen de los principales ataques de suplantación

IP Spoofing	Falsificación de la dirección IP de origen de un paquete.
DNS Spoofing	Manipulación de las respuestas DNS para dirigir al usuario hacia una dirección IP diferente.
SMTP Spoofing	Falsificación del origen aparente de un correo electrónico.
Rogue DHCP	Introducción de un servidor DHCP no autorizado que proporciona parámetros de configuración falsos.
DHCP Starvation	Agotamiento de las direcciones disponibles en el servidor DHCP para provocar una denegación de servicio.

Uso responsable de las herramientas de seguridad

Las herramientas utilizadas para analizar o simular ataques de Spoofing deben emplearse únicamente en **entornos controlados y con autorización**. Su finalidad en un entorno educativo es comprender el funcionamiento de los ataques y comprobar la eficacia de las medidas de protección.

2.6.3. Modificación del tráfico y las tablas de enrutamiento

La manipulación de rutas y tráfico constituye otro tipo de ataque activo. Una modificación de las tablas de enrutamiento puede provocar que los paquetes sigan una ruta diferente de la prevista, permitiendo desviar, observar o alterar comunicaciones.

Entre las herramientas y técnicas de auditoría asociadas al estudio de estas situaciones se citan pruebas sobre la pila TCP/IP, escaneo avanzado, traceroute y fingerprinting de sistemas operativos. Las medidas defensivas se basan en una configuración adecuada de los dispositivos de red, filtrado y monitorización.

3. Ataques web

Las aplicaciones web constituyen uno de los elementos más expuestos de una infraestructura informática, ya que proporcionan servicios accesibles a través de la red y reciben continuamente datos procedentes de los usuarios. Una vulnerabilidad en una aplicación web puede comprometer tanto la propia aplicación como la información almacenada en los sistemas que se encuentran detrás de ella.

La auditoría de seguridad de una aplicación web tiene como objetivo identificar las vulnerabilidades existentes, comprobar su impacto de forma controlada y establecer las medidas necesarias para mitigarlas. Para ello, además de los conocimientos sobre explotación de vulnerabilidades, es necesario utilizar herramientas específicas que permitan analizar las comunicaciones entre el cliente y el servidor.

Entre las herramientas empleadas habitualmente en este tipo de auditorías se encuentran:

- **Mantra (OWASP):** navegador orientado a pruebas de seguridad que integra diferentes extensiones para la auditoría de aplicaciones web. Entre sus funcionalidades se encuentran la manipulación de cabeceras HTTP, el *fingerprinting* de aplicaciones, la intercepción de peticiones, la modificación de parámetros, la edición de cookies y la modificación del agente de usuario.
- **ZAP Proxy (OWASP):** proxy de aplicación que permite interceptar y analizar las comunicaciones entre el navegador y la aplicación web, facilitando la realización de pruebas de seguridad.
- **Burp Suite:** conjunto de herramientas para la auditoría de aplicaciones web. Permite interceptar y modificar peticiones HTTP/HTTPS, analizar vulnerabilidades, realizar *spidering* y repetir o automatizar determinadas peticiones.
- **Charles Proxy:** proxy utilizado para interceptar y analizar las comunicaciones entre clientes y servidores, pudiendo emplearse también durante las pruebas de seguridad de aplicaciones web.

En los siguientes apartados se estudian algunas de las vulnerabilidades más relevantes que pueden encontrarse durante una auditoría de aplicaciones web.

3.1. Inyección de código SQL

La **inyección de código SQL** (*SQL Injection*) es una vulnerabilidad que aparece cuando una aplicación construye consultas SQL utilizando datos proporcionados por el usuario sin aplicar una validación y parametrización adecuadas.

El problema aparece cuando los datos introducidos por el usuario dejan de tratarse exclusivamente como información y pasan a modificar la estructura lógica de la consulta SQL. De esta forma, un atacante puede conseguir que la aplicación ejecute una consulta diferente de la prevista originalmente por sus desarrolladores.

Entre los objetivos que puede perseguir una inyección SQL se encuentran:

1. **Evitar mecanismos de autenticación**, por ejemplo, manipulando la consulta utilizada por un formulario de inicio de sesión.
2. **Acceder a información no autorizada** almacenada en la base de datos.
3. **Obtener información sobre la estructura de la base de datos**, como bases de datos, tablas, columnas o registros.
4. **Modificar información** cuando la cuenta utilizada por la aplicación dispone de permisos de escritura.
5. **Elevar privilegios** si la vulnerabilidad permite acceder o modificar información relacionada con los permisos de los usuarios.

Por tanto, una vulnerabilidad de este tipo puede afectar principalmente a la **confidencialidad** y a la **integridad** de la información, además de poder comprometer los mecanismos de autenticación y autorización de la aplicación.

Fundamentos de una inyección SQL Para comprender el funcionamiento de este tipo de vulnerabilidad puede considerarse una aplicación que dispone de un formulario de autenticación. El usuario introduce un nombre de usuario y una contraseña que posteriormente son utilizados por la aplicación para construir una consulta contra la base de datos.

Una consulta construida de forma insegura podría tener conceptualmente una estructura similar a la siguiente:

```
SELECT *
FROM usuarios
WHERE username = 'usuario'
  AND password = 'password';
```

Si los valores introducidos por el usuario se concatenan directamente en la consulta, un atacante puede introducir determinados caracteres y operadores SQL para alterar su lógica.

Por ejemplo, una entrada diseñada para modificar la condición de autenticación podría provocar que la consulta resultante tuviese una estructura equivalente a:

```
SELECT *
FROM usuarios
WHERE username = '000' OR '1'='1' --'
  AND password = 'seguridad';
```

En este caso, la expresión `'1'='1'` es verdadera y el comentario introducido después de ella puede provocar que el resto de la consulta original deje de tener efecto, dependiendo del sistema gestor de bases de datos utilizado.

El ejemplo permite comprender el principio fundamental de la vulnerabilidad: **la entrada proporcionada por el usuario modifica la lógica de la consulta que ejecuta la aplicación**.

Una aplicación no debe confiar en que los datos introducidos por el usuario sean seguros. La protección debe implementarse en el lado del servidor y, especialmente, mediante consultas parametrizadas o sentencias preparadas.

Información que puede obtenerse Una vez encontrada una vulnerabilidad de inyección SQL, su impacto dependerá de los permisos de la cuenta de base de datos utilizada por la aplicación y de las características del sistema gestor.

Entre la información que podría quedar expuesta se encuentra:

- Bases de datos disponibles.
- Tablas existentes.

- Columnas de las tablas.
- Registros almacenados.
- Información relacionada con los usuarios y sus privilegios.

Prevención de SQL Injection La principal medida de protección consiste en evitar que los datos proporcionados por el usuario puedan modificar la estructura de una consulta SQL.

Entre las medidas fundamentales se encuentran:

1. **Utilizar consultas parametrizadas o sentencias preparadas.** Los valores proporcionados por el usuario se tratan como datos y no como parte de la estructura de la consulta.
2. **Validar las entradas.** Los datos recibidos deben comprobarse de acuerdo con el formato y los valores que realmente necesita la aplicación.
3. **Aplicar el principio de mínimo privilegio.** La cuenta utilizada por la aplicación para acceder a la base de datos debe disponer únicamente de los permisos necesarios.
4. **Evitar mostrar información innecesaria en los mensajes de error.** Los errores de la base de datos pueden proporcionar información útil para comprender su estructura y facilitar la explotación de una vulnerabilidad.

3.2. Cross-Site Scripting (XSS)

El **Cross-Site Scripting (XSS)** es una vulnerabilidad que permite introducir contenido activo, habitualmente código JavaScript, en una aplicación web de forma que termine siendo interpretado por el navegador de otro usuario.

El problema aparece cuando la aplicación no controla adecuadamente los datos proporcionados por el usuario antes de incorporarlos a una página web.

A diferencia de una vulnerabilidad de inyección SQL, cuyo objetivo principal es modificar una consulta ejecutada en el servidor, en XSS el código inyectado termina ejecutándose en el **navegador del usuario víctima**.

Las consecuencias dependen del contexto en el que se ejecute el código y de los mecanismos de protección existentes. Entre ellas pueden encontrarse la modificación del contenido mostrado al usuario, la ejecución de acciones en su contexto o el acceso a información que resulte accesible desde el navegador.

Los dos tipos principales tratados en este contexto son el XSS reflejado y el XSS almacenado.

XSS reflejado El **XSS reflejado** (*Reflected XSS*) se produce cuando el contenido proporcionado por el usuario se incorpora inmediatamente a la respuesta generada por la aplicación web, sin quedar almacenado de forma permanente.

De forma simplificada, el proceso puede representarse mediante los siguientes pasos:

1. El atacante prepara una petición que contiene contenido malicioso.
2. La víctima accede a dicha petición, normalmente mediante un enlace o una URL manipulada.
3. El servidor recibe el contenido proporcionado.
4. La aplicación incorpora dicho contenido a la respuesta sin neutralizarlo correctamente.
5. El navegador de la víctima interpreta el contenido recibido.

La característica fundamental es que el contenido malicioso **se refleja en la respuesta del servidor**, en lugar de permanecer almacenado en la aplicación.

XSS almacenado o persistente El **XSS almacenado** (*Stored XSS*) se produce cuando el contenido introducido por el atacante queda almacenado en algún sistema de persistencia de la aplicación, como una base de datos.

Un ejemplo típico sería un foro en el que los mensajes introducidos por los usuarios se almacenan en la base de datos y posteriormente se muestran a otros usuarios.

El funcionamiento puede resumirse de la siguiente forma:

1. El atacante introduce contenido manipulado en un formulario de la aplicación.
2. La aplicación almacena dicho contenido.
3. Otro usuario accede posteriormente a la página que contiene el contenido almacenado.
4. La aplicación recupera el contenido y lo incorpora a la página.
5. El navegador interpreta el contenido como código ejecutable.

La diferencia fundamental respecto al XSS reflejado es que en este caso **el contenido malicioso permanece almacenado en la aplicación**, por lo que puede afectar posteriormente a los usuarios que accedan al recurso comprometido.

Otros tipos relacionados Además de los tipos anteriores, en el documento se mencionan otras categorías relacionadas con la ejecución de contenido o la interacción no deseada entre aplicaciones, entre ellas:

- **DOM XSS:** vulnerabilidad en la que la manipulación insegura del DOM mediante código ejecutado en el navegador permite introducir contenido controlado por el atacante.
- **Cross-Site Request Forgery (CSRF):** técnica mediante la cual se intenta conseguir que el navegador de un usuario autenticado realice una petición no deseada a una aplicación.
- **Server-Side Request Forgery (SSRF):** vulnerabilidad que permite provocar que el servidor realice peticiones hacia recursos que el atacante no debería poder alcanzar directamente.

El documento también recoge otras denominaciones históricas o específicas, como XSF, XFS, XZS y XAS. Estas denominaciones no presentan el mismo grado de uso o estandarización que XSS, CSRF o SSRF, por lo que deben interpretarse dentro del contexto en el que aparecen.

Prevención de XSS La protección frente a XSS debe realizarse principalmente mediante un tratamiento seguro de los datos que proceden del usuario y mediante una correcta generación de las respuestas.

Entre las medidas más importantes se encuentran:

1. **Validar las entradas** de acuerdo con el formato esperado.
2. **Escapar o codificar los datos antes de incorporarlos al HTML**, teniendo en cuenta el contexto concreto en el que se insertan.
3. **Evitar interpretar como HTML o código los datos que deben tratarse únicamente como texto**.
4. **Validar los datos en el servidor**. Las comprobaciones realizadas exclusivamente mediante JavaScript en el navegador no constituyen una protección suficiente, ya que pueden ser modificadas o evitadas por el cliente.
5. **Utilizar mecanismos adicionales de defensa**, como una política de seguridad de contenidos (*Content Security Policy*, CSP), cuando resulte apropiado.

Es importante destacar que el uso de listas negras que simplemente buscan determinadas cadenas, como las etiquetas `<script>`, no constituye por sí solo una defensa completa frente a XSS. La protección debe basarse en una validación adecuada y, especialmente, en la codificación contextual de las salidas.

Durante una auditoría pueden emplearse herramientas específicas para automatizar determinadas pruebas de detección de XSS. El documento menciona, entre otras, **XSSer** y **XSSniper**.

3.3. Otros tipos de ataques web

Además de las inyecciones SQL y las vulnerabilidades XSS, existen otros ataques relacionados con un tratamiento incorrecto de los datos proporcionados por el usuario. El documento destaca especialmente aquellos relacionados con la gestión de ficheros y con la inclusión de recursos.

Entre ellos se encuentran:

- **Unrestricted File Upload**.
- **Local File Inclusion (LFI)**.
- **Remote File Inclusion (RFI)**.
- **Remote Code Execution (RCE)**.

Unrestricted File Upload La vulnerabilidad **Unrestricted File Upload** aparece cuando una aplicación permite subir ficheros sin aplicar controles adecuados sobre sus características.

El riesgo depende de cómo procese posteriormente la aplicación los ficheros subidos y de los permisos existentes en el servidor.

Entre las consecuencias posibles se encuentran:

1. **Subida de ficheros ejecutables.** Si el servidor permite interpretar el tipo de fichero subido, un atacante podría conseguir ejecutar código en el servidor.
2. **Consumo de espacio de almacenamiento.** La subida de ficheros de gran tamaño puede llegar a agotar el espacio disponible en el sistema de archivos.
3. **Manipulación de rutas o nombres de fichero.** Una gestión incorrecta del nombre o de la ubicación de los ficheros puede provocar accesos no autorizados o sobrescrituras.

Para reducir estos riesgos deben aplicarse controles tanto sobre el fichero recibido como sobre la forma en que se almacena.

Entre las principales medidas se encuentran:

1. **Restringir el tipo de fichero permitido.** No debe confiarse únicamente en la extensión proporcionada por el cliente; la aplicación debe comprobar que el contenido corresponde realmente al tipo esperado.
2. **Limitar el tamaño máximo** de los ficheros que pueden subirse.
3. **Sanear el nombre del fichero**, evitando que el usuario pueda controlar directamente la ruta donde se almacenará.
4. **Separar el almacenamiento de ficheros subidos de las zonas ejecutables del servidor**, siempre que sea posible.
5. **Impedir que los ficheros subidos puedan ejecutarse directamente** en el servidor cuando la funcionalidad únicamente requiere almacenarlos o descargarlos.

Local File Inclusion (LFI) La vulnerabilidad **Local File Inclusion (LFI)** aparece cuando una aplicación permite que un parámetro controlado por el usuario determine qué recurso o fichero local debe incluirse.

Si la aplicación no valida correctamente dicho parámetro, un atacante puede intentar acceder a ficheros locales que no deberían estar disponibles a través de la aplicación web.

El impacto dependerá de los permisos del proceso que ejecuta la aplicación y de los ficheros accesibles desde dicho proceso.

Remote File Inclusion (RFI) La vulnerabilidad **Remote File Inclusion (RFI)** presenta un problema similar al LFI, pero en este caso la aplicación puede llegar a incluir un recurso situado en un sistema remoto controlado por el atacante.

Cuando una aplicación permite este comportamiento sin controles adecuados, el riesgo puede ser considerablemente mayor, ya que el recurso remoto podría contener código que posteriormente fuese interpretado por el servidor.

En aplicaciones PHP, el documento señala como medida de protección la desactivación de la opción `allow_url_include` cuando no sea necesaria.

Remote Code Execution (RCE) La **Remote Code Execution (RCE)** es una vulnerabilidad que permite a un atacante conseguir que el servidor de la aplicación ejecute código o comandos controlados por él.

Su gravedad depende del contexto de ejecución y de los privilegios del proceso comprometido. En determinados escenarios, una RCE puede permitir comprometer completamente el servidor que aloja la aplicación web.

Por este motivo, las vulnerabilidades de inclusión de ficheros y otras vulnerabilidades de procesamiento de entradas deben analizarse también teniendo en cuenta la posibilidad de que puedan utilizarse como parte de una cadena de explotación que termine provocando ejecución de código.

3.4. Nikto

Nikto es una herramienta de código abierto utilizada para realizar auditorías de servidores web. Está desarrollada en Perl y permite analizar servidores que utilizan HTTP o HTTPS con el objetivo de identificar configuraciones problemáticas, componentes potencialmente vulnerables y otros elementos que deberían revisarse durante una auditoría.

Entre la información que puede proporcionar un análisis se encuentra:

- Versión del servidor web.
- Métodos HTTP habilitados.
- Sistema operativo del equipo que aloja la aplicación.
- Posibles vulnerabilidades asociadas a versiones de software desactualizadas.
- Información accesible públicamente.
- Problemas de configuración del servidor.
- Ficheros o scripts que pueden encontrarse instalados por defecto en el servidor web.

La sintaxis general indicada en el documento es:

```
nikto [-h destino] [opciones]
```

Entre las opciones más relevantes se encuentran:

`-h`	Permite especificar el destino que se desea analizar.
`-ssl`	Permite indicar que el análisis se realiza sobre HTTPS cuando sea necesario especificarlo explícitamente.
`-debug`	Muestra información detallada durante la ejecución del análisis.
`-useproxy`	Permite realizar las peticiones a través de un proxy configurado previamente.
`-evasion`	Permite utilizar determinadas técnicas de evasión durante las pruebas. Su utilización debe limitarse a auditorías autorizadas y entornos controlados.
`-F`	Permite especificar el formato del informe de salida y se utiliza conjuntamente con `-o`.
`-o`	Permite indicar el fichero en el que se almacenará el resultado del análisis.

Un ejemplo básico de ejecución sería:

```
nikto -h https://servidor.ejemplo
```

El resultado obtenido debe interpretarse como **información para una auditoría**, no como una prueba definitiva de que una vulnerabilidad sea explotable. Los resultados deben verificarse posteriormente mediante pruebas específicas y controladas.

Idea clave

Las herramientas de auditoría web permiten automatizar la identificación de determinados problemas, pero no sustituyen al análisis del auditor. Un resultado detectado por una herramienta debe ser interpretado y, cuando corresponda, validado mediante una prueba controlada antes de considerarlo una vulnerabilidad confirmada.

Seguridad y uso responsable

Las herramientas de auditoría y explotación de vulnerabilidades deben utilizarse únicamente sobre sistemas para los que se disponga de autorización. En un entorno profesional, las pruebas deben realizarse dentro del alcance definido para la auditoría y procurando evitar impactos sobre la disponibilidad o integridad de los sistemas.

4. Ataques a contraseñas. Fases de registro y autenticación

Los sistemas de autenticación basados en contraseñas constituyen uno de los puntos de ataque más habituales. Un atacante puede intentar obtener una contraseña mediante la prueba sistemática de candidatos, aprovechar contraseñas débiles o reutilizadas, engañar al usuario para que revele sus credenciales o tratar de obtener los valores almacenados por el sistema.

Desde el punto de vista de la seguridad, es importante distinguir entre los ataques realizados contra un servicio de autenticación en funcionamiento y los ataques realizados **fuera de línea**, por ejemplo, después de obtener una base de datos que contiene los valores derivados de las contraseñas.

4.1. Fuerza bruta y ataques de diccionario

El **ataque de fuerza bruta** consiste en probar sistemáticamente un conjunto de posibles contraseñas hasta encontrar aquella que permite la autenticación. El espacio de búsqueda depende de la longitud de la contraseña y del conjunto de caracteres considerado.

Si una contraseña tiene una longitud L y se utilizan N caracteres posibles, el número máximo de combinaciones que habría que probar es:

$$N^L$$

Por tanto, aumentar la longitud de una contraseña incrementa considerablemente el espacio de búsqueda. En un ataque real, además, la velocidad de las pruebas dependerá de si el ataque se realiza contra un servicio remoto o contra valores de contraseña obtenidos previamente.

Idea clave

La eficacia de un ataque de fuerza bruta no depende únicamente del número de caracteres utilizados. También es fundamental conocer si el atacante puede realizar intentos en línea, limitados por el propio servicio, o si dispone de los valores de las contraseñas para realizar un ataque fuera de línea.

En los ataques contra un servicio en línea, cada intento debe ser procesado por el sistema de autenticación. Por ello, mecanismos como la limitación de intentos, los retrasos progresivos y otros controles de detección dificultan considerablemente la automatización del ataque.

El **ataque de diccionario** utiliza una estrategia diferente. En lugar de probar todas las combinaciones posibles, emplea una lista de candidatos que contiene palabras, contraseñas habituales, combinaciones conocidas y otras elecciones que los usuarios suelen realizar. Este procedimiento suele ser mucho más eficiente que la fuerza bruta cuando las contraseñas han sido escogidas por personas y presentan patrones predecibles.

Estas listas reciben habitualmente el nombre de **wordlists**. Pueden contener desde palabras de un idioma hasta contraseñas obtenidas de filtraciones anteriores o variantes de términos habituales.

Una variante especialmente relevante consiste en combinar una palabra de diccionario con transformaciones previsibles, como añadir números, cambiar mayúsculas y minúsculas o incorporar símbolos. Este tipo de estrategia permite reducir el espacio de búsqueda aprovechando patrones habituales en la elección de contraseñas.

Las **wordlists** pueden emplearse junto con herramientas de auditoría de contraseñas como **John the Ripper**. También existen herramientas como **Crunch**, orientadas a la generación de listas de candidatos bajo determinados criterios.

Medidas de protección

Las principales medidas para dificultar los ataques de adivinación de contraseñas son:

- **Limitación de intentos:** restringir la frecuencia o el número de intentos de autenticación fallidos.
- **Retrasos progresivos:** incrementar el tiempo de espera después de sucesivos intentos fallidos, haciendo menos eficiente la automatización.
- **Bloqueos temporales:** suspender temporalmente la autenticación de una cuenta cuando se detecta un número anómalo de intentos.
- **Detección de credenciales comprometidas:** impedir el uso de contraseñas conocidas por haber aparecido en filtraciones anteriores.
- **Autenticación multifactor:** añadir factores adicionales a la contraseña para que el conocimiento de esta no sea suficiente para completar la autenticación.

El bloqueo permanente de una cuenta ante un número reducido de intentos debe utilizarse con precaución, ya que un atacante podría aprovecharlo para provocar una **denegación de servicio** contra usuarios legítimos.

4.2. Ingeniería social y keylogger

No todos los ataques contra las contraseñas requieren romper técnicamente el mecanismo de autenticación. En muchos casos, el objetivo consiste en conseguir que el propio usuario revele sus credenciales.

La **ingeniería social** engloba las técnicas que aprovechan factores humanos, como la confianza, la urgencia o el desconocimiento, para conseguir información que permita acceder a un sistema. El **phishing** es uno de sus ejemplos más conocidos: el atacante intenta dirigir a la víctima hacia un sitio, mensaje o comunicación fraudulenta con el objetivo de obtener credenciales u otra información sensible.

Otro mecanismo de ataque es el **keylogger**. Se trata de un software o dispositivo capaz de registrar las pulsaciones realizadas por el usuario. Si un atacante consigue instalarlo o controlar el equipo donde se ejecuta, puede capturar las credenciales introducidas mediante el teclado.

> Idea clave
>
> Una contraseña puede ser técnicamente robusta y, aun así, quedar comprometida si el usuario la introduce en un sitio fraudulento o si el dispositivo desde el que se utiliza está comprometido.

Por este motivo, la protección de las contraseñas no debe limitarse al algoritmo empleado para almacenarlas. También es necesario proteger el proceso completo de autenticación y el dispositivo desde el que se realiza.

4.3. Factores de autenticación

La **autenticación** es el proceso mediante el cual un sistema comprueba que una entidad es quien afirma ser. Para realizar esta comprobación pueden utilizarse diferentes factores de autenticación.

Tradicionalmente se distinguen tres categorías:

Algo que sabes
: Información que conoce el usuario, como una contraseña, un PIN o una frase secreta.

Algo que tienes
: Un objeto o dispositivo que posee el usuario, como una tarjeta, una llave de seguridad o un dispositivo capaz de generar códigos de autenticación.

Algo que eres
: Una característica biométrica del usuario, como una huella dactilar o determinadas características del rostro o del iris.

Cuando un sistema combina dos factores pertenecientes a categorías diferentes se habla de **autenticación multifactor (MFA)**. Por ejemplo, una contraseña combinada con una llave de seguridad constituye una autenticación basada en dos factores diferentes.

Es importante distinguir entre utilizar dos mecanismos y utilizar realmente dos factores. Por ejemplo, solicitar una contraseña y después un código adicional que se envía al mismo canal puede proporcionar una protección adicional, pero no todos los mecanismos que se presentan como "doble autenticación" ofrecen el mismo nivel de resistencia frente a ataques como el phishing.

4.4. Fases de registro y autenticación

Los sistemas basados en contraseñas pueden analizarse diferenciando dos momentos fundamentales: el **registro** de la credencial y la **autenticación** posterior.

Fase de registro

La **fase de registro** tiene lugar cuando se crea una cuenta o cuando se establece una nueva contraseña. El usuario proporciona los datos necesarios para crear su identidad digital y establece una credencial.

Una implementación segura **no debe almacenar la contraseña en texto plano**. Tampoco debe ser necesario almacenarla mediante un mecanismo de cifrado reversible para poder comprobarla posteriormente.

En su lugar, el sistema debe utilizar una función específica de derivación y almacenamiento de contraseñas. De forma simplificada:

$$\text{contraseña} + \text{salt} \longrightarrow \text{función de derivación} \longrightarrow \text{valor almacenado}$$

El **salt** es un valor aleatorio y único asociado a cada contraseña. No tiene que mantenerse secreto y puede almacenarse junto con el resultado de la función de derivación.

El objetivo del salt es evitar que dos usuarios que hayan elegido la misma contraseña produzcan necesariamente el mismo valor almacenado y, especialmente, dificultar el uso de tablas precalculadas como las **Rainbow Tables**.

Para el almacenamiento de contraseñas no deben utilizarse directamente funciones hash rápidas y genéricas como MD5, SHA-1 o SHA-256. Estas funciones están diseñadas para calcularse rápidamente, mientras que un sistema de almacenamiento de contraseñas debe utilizar funciones deliberadamente costosas y, preferentemente, resistentes a ataques acelerados mediante hardware especializado.

Entre las alternativas utilizadas actualmente destacan:

- **Argon2id**, especialmente adecuado para nuevas aplicaciones y diseñado para dificultar ataques mediante grandes capacidades de procesamiento.
- **scrypt**, otra función de derivación diseñada para incrementar el coste computacional y de memoria de los ataques.
- **bcrypt**, todavía utilizado en sistemas existentes, aunque se considera principalmente una opción de compatibilidad con sistemas heredados.
- **PBKDF2**, utilizado especialmente en entornos en los que existen requisitos de compatibilidad o validación criptográfica específicos.

Estas funciones incorporan parámetros de coste que permiten ajustar el esfuerzo necesario para calcular cada valor. A medida que aumenta la capacidad de los sistemas informáticos, estos parámetros pueden incrementarse para mantener un coste adecuado.

Fase de autenticación

La **fase de autenticación** tiene lugar cuando el usuario intenta acceder al sistema.
El proceso puede resumirse de la siguiente forma:

1. El usuario proporciona su identificador y su contraseña.
2. El sistema recupera del almacén de credenciales el salt y los parámetros asociados a esa cuenta.
3. Se aplica a la contraseña proporcionada la misma función de derivación utilizada durante el registro.
4. El resultado obtenido se compara con el valor almacenado.
5. Si la verificación es correcta, el sistema considera válida la credencial y permite continuar con el proceso de autorización.

De forma simplificada:

$$\text{contraseña introducida} + \text{salt} \longrightarrow \text{función de derivación} \longrightarrow \text{valor calculado}$$

A continuación:

$$\text{valor calculado} \stackrel{?}{=} \text{valor almacenado}$$

La contraseña original no necesita recuperarse en ningún momento. Por ello, un sistema correctamente diseñado debe proporcionar mecanismos para **restablecer** una contraseña olvidada, pero no para recuperarla y mostrar su valor original.

Además del almacenamiento seguro, las credenciales deben transmitirse mediante un **canal protegido**, como HTTPS mediante TLS, para evitar que puedan ser interceptadas durante el proceso de autenticación.

Importante

El hash de una contraseña no es una contraseña cifrada. El cifrado está diseñado para poder recuperar el dato original mediante una clave; el almacenamiento de contraseñas debe utilizar una función de derivación unidireccional específicamente diseñada para dificultar la recuperación de la contraseña mediante pruebas masivas.

4.5. Rainbow Tables

Las **Rainbow Tables** son tablas precalculadas utilizadas históricamente para acelerar la recuperación de contraseñas a partir de determinados valores hash.

Su funcionamiento se basa en construir previamente cadenas que combinan sucesivas operaciones de hash y funciones de reducción. En lugar de almacenar todos los pares posibles:

$$\text{contraseña} \longrightarrow \text{hash}$$

se almacenan únicamente determinados elementos de las cadenas generadas. Cuando se dispone de un hash objetivo, se intenta determinar si este puede aparecer dentro de alguna de las cadenas precalculadas y, a partir de ella, reconstruir una posible contraseña candidata.

Las funciones de reducción utilizadas en este proceso **no invierten matemáticamente la función hash**. Su finalidad es transformar un valor hash en otro candidato que permita continuar la construcción de la cadena.

El principal compromiso de este mecanismo se encuentra entre **espacio de almacenamiento y tiempo de cálculo**: generar tablas grandes requiere un elevado almacenamiento y tiempo de preparación, mientras que tablas más pequeñas requieren más cálculos durante la búsqueda.

Las Rainbow Tables son mucho menos eficaces frente a sistemas modernos que emplean correctamente un **salt único por contraseña**. Como cada contraseña se procesa con un valor diferente, una tabla precalculada para un determinado salt no puede reutilizarse directamente para otros usuarios.

Por tanto, actualmente su relevancia se encuentra principalmente en el estudio de sistemas de almacenamiento de contraseñas antiguos o mal diseñados.

Idea clave

El uso de un salt aleatorio y único por contraseña impide que una única Rainbow Table sea reutilizable de forma general contra una base de datos de credenciales. Por este motivo, el almacenamiento moderno de contraseñas debe utilizar siempre funciones de derivación con salt correctamente gestionados.

4.6. Herramientas de cracking de contraseñas

Las herramientas de cracking permiten automatizar diferentes técnicas de auditoría de credenciales. Su utilización debe realizarse exclusivamente sobre sistemas propios o sobre entornos para los que se disponga de autorización.

Entre las herramientas mencionadas en este contexto se encuentran:

John the Ripper
: Herramienta orientada al análisis y recuperación de contraseñas a partir de diferentes formatos de credenciales. Puede utilizar listas de candidatos y distintas técnicas de cracking.

Hashcat
: Herramienta especializada en la recuperación de contraseñas a partir de hashes, con capacidad para aprovechar hardware de alto rendimiento, especialmente GPU.

Hydra
: Herramienta orientada principalmente a realizar pruebas automatizadas de autenticación contra servicios remotos. Es compatible con numerosos protocolos y permite utilizar listas de usuarios y contraseñas.

Medusa
: Herramienta de auditoría de autenticación remota que permite realizar pruebas automatizadas basadas en diccionarios sobre distintos servicios.

Ncrack
: Herramienta desarrollada para realizar auditorías de servicios de autenticación de red y probar credenciales frente a diferentes protocolos.

Crunch
: Herramienta destinada a la generación de *wordlists* a partir de conjuntos de caracteres y restricciones definidas.

Ophcrack
: Herramienta histórica orientada a la recuperación de determinadas contraseñas de sistemas Windows mediante el uso de Rainbow Tables.

Estas herramientas permiten diferenciar dos escenarios de ataque especialmente importantes:

1. **Cracking en línea:** las credenciales se prueban directamente contra un servicio de autenticación. El servidor puede detectar y limitar los intentos, por lo que mecanismos como el *rate limiting*, los retrasos progresivos y la detección de actividad anómala son fundamentales.
2. **Cracking fuera de línea:** el atacante dispone de hashes o de otros valores derivados de las contraseñas y puede realizar las pruebas sin interactuar con el servicio de autenticación. En este escenario no existe el mismo límite de intentos y adquieren especial importancia la calidad de la contraseña y el algoritmo de almacenamiento empleado.

Resumen de la sección

La seguridad de un sistema de autenticación no depende únicamente de que la contraseña sea difícil de adivinar. Es necesario proteger todo el ciclo de vida de la credencial: creación, almacenamiento, transmisión, autenticación, recuperación y revocación.
Las medidas fundamentales incluyen el uso de contraseñas suficientemente largas y no comprometidas, la limitación de intentos de autenticación, el uso de autenticación multifactor cuando el nivel de riesgo lo requiera y el almacenamiento mediante funciones de derivación de contraseñas modernas, con salt único por credencial y parámetros de coste adecuados.

Los mecanismos de autenticación basados en contraseñas constituyen un punto crítico de la seguridad. Pueden distinguirse ataques que prueban contraseñas de aquellos que intentan obtenerlas mediante ingeniería social o captura de las pulsaciones del usuario.

5. Seguridad en la conexión con redes públicas

Las redes públicas permiten acceder a Internet desde entornos que no están bajo nuestro control directo, como redes Wi-Fi de hoteles, cafeterías, aeropuertos, bibliotecas o centros educativos. Esta situación introduce riesgos adicionales, ya que el usuario no puede asumir que los dispositivos de red, el punto de acceso o el resto de equipos conectados sean confiables.

El problema no reside únicamente en que una red sea "pública". Una red privada también puede sufrir ataques si está mal configurada. Sin embargo, en una red pública aumenta la exposición a amenazas como la interceptación del tráfico, los ataques de intermediario (*Man-in-the-Middle*, MitM), los puntos de acceso fraudulentos y la suplantación de servicios.

Por este motivo, la seguridad de una comunicación no debe depender exclusivamente de la red utilizada. Debe garantizarse mediante mecanismos de protección aplicados en los extremos de la comunicación y, cuando sea necesario, mediante canales cifrados.

Entre los principales mecanismos relacionados con la conexión segura a redes públicas se encuentran:

1. **Identificación y autenticación digital**, mediante certificados digitales y mecanismos de firma electrónica.
2. **Protocolos seguros de administración remota**, como SSH.
3. **Redes privadas virtuales (VPN)**, para crear canales protegidos sobre redes no confiables.
4. **HTTPS**, basado actualmente en TLS, para proteger las comunicaciones web.
5. **Seguridad de las redes inalámbricas**, utilizando mecanismos de autenticación y cifrado actuales.

Idea clave

Una red pública debe considerarse un medio de transporte no confiable. La seguridad debe proporcionarse mediante mecanismos criptográficos y de autenticación situados en los extremos de la comunicación. Por ello, conectarse a una red pública no implica necesariamente que toda comunicación sea insegura, pero sí exige utilizar correctamente los protocolos de seguridad.

5.1. Identificación digital

La **identificación digital** permite asociar una identidad real con una identidad utilizada en una comunicación electrónica. Su finalidad es proporcionar garantías sobre la identidad de las partes que participan en una operación.

No debe confundirse la identificación digital con la **identidad digital**. La identidad digital comprende el conjunto de información y representaciones asociadas a una persona en el entorno digital, mientras que la identificación digital hace referencia a los mecanismos empleados para acreditar quién es esa persona ante un sistema.

Entre los mecanismos de identificación se encuentran:

- **Contraseñas**, basadas en un secreto conocido por el usuario.
- **Tarjetas o dispositivos de identificación**, que almacenan o proporcionan información de autenticación.
- **Sistemas biométricos**, basados en características físicas o comportamentales.
- **Certificados digitales**, que permiten vincular una identidad con una clave pública mediante una autoridad de confianza.

En las comunicaciones realizadas a través de redes públicas resulta especialmente importante disponer de mecanismos que permitan comprobar la identidad de los participantes. El objetivo es evitar que un atacante pueda hacerse pasar por otra persona o servicio.

> **Importante**
>
> La identificación, la autenticación y la autorización son conceptos diferentes. La autenticación permite comprobar quién es una entidad; la autorización determina qué acciones puede realizar una vez autenticada.

5.2. Firma electrónica y certificado digital

La **firma digital** es un mecanismo criptográfico que permite comprobar que un documento o mensaje ha sido firmado utilizando la clave privada correspondiente a una determinada identidad y que los datos firmados no han sido modificados posteriormente.

Su funcionamiento se basa en criptografía asimétrica. De forma simplificada, el proceso puede representarse como:

$$\text{Documento} \longrightarrow \text{Función hash} \longrightarrow \text{Resumen} \longrightarrow \text{Firma con clave privada}$$

El receptor puede utilizar la clave pública correspondiente para verificar la firma:

$$\text{Firma} + \text{Clave pública} \longrightarrow \text{Verificación}$$

Una firma digital permite comprobar fundamentalmente:

1. **Integridad:** permite detectar modificaciones realizadas sobre los datos después de su firma.
2. **Autenticidad del firmante:** permite comprobar que la firma corresponde a la clave privada asociada con la identidad certificada.
3. **Evidencia de autoría:** proporciona evidencias criptográficas sobre la realización de la firma. Las consecuencias jurídicas concretas dependen del contexto y de la legislación aplicable.

Es importante no confundir **firma digital** con **cifrado**. La firma digital está orientada principalmente a proporcionar autenticidad e integridad; no proporciona por sí misma confidencialidad. Para proteger la confidencialidad es necesario utilizar mecanismos de cifrado.

> **Importante**
>
> Firmar digitalmente un documento no significa cifrarlo. Un documento puede estar firmado y seguir siendo completamente legible. Si además se necesita confidencialidad, debe utilizarse un mecanismo de cifrado.

Certificado digital

Una de las dificultades de la criptografía de clave pública consiste en determinar si una determinada clave pública pertenece realmente a la entidad que afirma ser su propietaria.

Un **certificado digital** permite solucionar este problema vinculando una identidad con una clave pública mediante la firma de una **Autoridad de Certificación (CA)**.

De forma simplificada, un certificado contiene información como:

- Identidad del titular.
- Clave pública del titular.

- Información sobre el algoritmo y los parámetros criptográficos utilizados.
- Periodo de validez.
- Identificación de la autoridad que emite el certificado.
- Número de serie.
- Extensiones adicionales.
- Firma digital de la autoridad certificadora.

El certificado no contiene la clave privada del usuario. Esta debe permanecer bajo el control exclusivo de su propietario.

Cuando un receptor recibe un certificado, puede verificar la firma de la autoridad certificadora y comprobar diferentes condiciones, entre ellas:

1. Que la firma de la autoridad certificadora sea válida.
2. Que el certificado se encuentre dentro de su periodo de validez.
3. Que el nombre o identidad para la que se utiliza el certificado coincida con la comunicación.
4. Que el certificado no haya sido revocado, cuando corresponda comprobar su estado.
5. Que la cadena de confianza termine en una autoridad certificadora confiable.

5.3. Infraestructura de clave pública (PKI)

La **Infraestructura de Clave Pública (PKI, Public Key Infrastructure)** comprende el conjunto de componentes, procedimientos y políticas utilizados para gestionar certificados digitales y claves criptográficas dentro de una infraestructura de confianza.

Una PKI permite establecer relaciones de confianza entre entidades que no necesitan conocerse previamente.

Entre sus componentes y conceptos fundamentales se encuentran:

Autoridad de Certificación (CA)
: Entidad responsable de emitir y firmar certificados digitales de acuerdo con unas políticas de certificación determinadas.

Autoridad de Registro (RA)
: Entidad o función encargada de realizar determinadas tareas de identificación y registro de los solicitantes antes de la emisión de un certificado.

Autoridad de Validación (VA)
: Componente que puede proporcionar información sobre el estado de validez de los certificados, por ejemplo, mediante mecanismos de consulta.

Repositorio
: Infraestructura donde pueden publicarse certificados, listas de revocación u otra información relacionada con la PKI.

Certificado digital
: Estructura que vincula una identidad con una clave pública y que está firmada por una autoridad certificadora.

Las autoridades certificadoras pueden organizarse mediante una **cadena de confianza**. Un certificado puede estar firmado por una CA intermedia, cuyo propio certificado está firmado por otra CA hasta llegar a una **CA raíz** que el sistema considera confiable.

$$\text{CA raíz} \rightarrow \text{CA intermedia} \rightarrow \text{Certificado del usuario o servicio}$$

Los sistemas operativos y navegadores mantienen almacenes de autoridades de confianza que permiten validar estas cadenas.

5.4. Revocación y ciclo de vida de los certificados

Un certificado no debe considerarse válido únicamente porque su firma criptográfica sea correcta. También es necesario comprobar su estado y su periodo de validez.

Un certificado puede dejar de ser confiable antes de su fecha de expiración, por ejemplo, si la clave privada asociada se ha comprometido.

Para gestionar estas situaciones existen mecanismos como:

- **CRL (Certificate Revocation List):** lista publicada por una autoridad certificadora que contiene certificados que han sido revocados.
- **OCSP (Online Certificate Status Protocol):** protocolo que permite consultar el estado de un certificado a un servicio de validación.

En sistemas modernos también es habitual que determinados mecanismos de seguridad reduzcan la dependencia de consultas OCSP en tiempo real mediante técnicas de distribución o almacenamiento del estado de los certificados.

Idea clave

La confianza en un certificado no depende exclusivamente de que su firma sea válida. También deben comprobarse su cadena de confianza, periodo de validez, identidad del titular y, cuando proceda, su estado de revocación.

5.5. Conexiones SSH

SSH (Secure Shell) es un protocolo diseñado para proporcionar comunicaciones seguras sobre redes potencialmente no confiables. Se utiliza principalmente para la administración remota de sistemas, aunque también permite otras funciones como la transferencia segura de archivos y la creación de túneles.

SSH proporciona, mediante mecanismos criptográficos, propiedades como:

- **Confidencialidad** de los datos transmitidos.
- **Integridad** de los mensajes.
- **Autenticación del servidor**.
- **Autenticación del usuario**, mediante contraseña, claves públicas u otros mecanismos compatibles.

Una conexión SSH comienza estableciendo los parámetros criptográficos necesarios y autenticando al servidor. Posteriormente se autentica el usuario y se establece una sesión protegida.

La autenticación mediante **clave pública** evita tener que transmitir una contraseña como mecanismo principal de autenticación. El usuario dispone de un par de claves:

$$\{\text{clave privada}, \text{clave pública}\}$$

La clave privada debe mantenerse secreta, mientras que la clave pública puede instalarse en el sistema remoto.

Buenas prácticas

Para utilizar SSH de forma segura deben mantenerse actualizados el cliente y el servidor, proteger adecuadamente las claves privadas, utilizar algoritmos y configuraciones criptográficas actuales y, cuando sea posible, aplicar mecanismos adicionales como MFA o restricciones de acceso.

5.6. Redes privadas virtuales (VPN)

Una **VPN (Virtual Private Network)** permite establecer un canal de comunicación protegido a través de una red que no se considera confiable, como Internet.

La idea fundamental consiste en encapsular el tráfico y protegerlo mediante mecanismos criptográficos antes de enviarlo a través de la red pública.

De forma simplificada:

$$\text{Red privada} \longrightarrow \boxed{\text{Túnel VPN cifrado}} \longrightarrow \text{Red pública} \longrightarrow \text{Red privada}$$

Dependiendo de la tecnología utilizada, una VPN puede proporcionar:

- **Confidencialidad**, mediante el cifrado del tráfico.
- **Integridad**, mediante mecanismos que permiten detectar modificaciones.
- **Autenticación**, para verificar los extremos de la comunicación.
- **Acceso remoto seguro** a recursos internos.

Existen diferentes tecnologías VPN. Entre las más conocidas se encuentran:

- **IPsec**, conjunto de protocolos que proporciona seguridad en la capa de red y que se utiliza habitualmente para establecer VPN de acceso remoto o entre redes.
- **OpenVPN**, solución VPN basada en TLS y ampliamente utilizada.
- **WireGuard**, protocolo VPN moderno diseñado con una arquitectura criptográfica relativamente sencilla y orientado a ofrecer un funcionamiento eficiente.

Una VPN no convierte automáticamente en segura cualquier actividad realizada sobre ella. La seguridad dependerá de la correcta configuración de los extremos, de los algoritmos utilizados, de la autenticación y de la protección de las credenciales.

Importante

Una VPN protege principalmente el tráfico entre los extremos del túnel. No sustituye a otras medidas de seguridad como HTTPS, autenticación multifactor, control de acceso o protección del dispositivo.

5.7. HTTPS y seguridad en la navegación web

HTTPS (HTTP Secure) es HTTP transportado sobre una conexión protegida mediante **TLS (Transport Layer Security)**.

Su objetivo es proteger la comunicación entre el cliente y el servidor frente a la observación o modificación del tráfico durante su transmisión.

En una conexión HTTPS intervienen principalmente:

- **Cifrado**: protege la confidencialidad de los datos transmitidos.
- **Integridad**: permite detectar modificaciones del tráfico.
- **Autenticación del servidor**: normalmente mediante un certificado digital emitido por una autoridad de certificación reconocida por el cliente.

El establecimiento de una conexión TLS implica una fase de negociación en la que cliente y servidor acuerdan los parámetros criptográficos y se autentica el servidor mediante su certificado.

En las implementaciones actuales debe utilizarse **TLS 1.2 o, preferentemente, TLS 1.3**. Las versiones antiguas de SSL y las versiones obsoletas de TLS no deben utilizarse.

> Importante
>
> El icono del candado del navegador no significa que el sitio web sea legítimo o que su contenido sea confiable. Indica que existe una conexión HTTPS correctamente establecida con un certificado válido para el dominio. Un sitio malicioso también puede utilizar HTTPS.

Además, HTTPS no protege frente a todos los riesgos existentes en una red pública. Por ejemplo, no evita que un usuario introduzca sus credenciales voluntariamente en una página de phishing ni protege un dispositivo que ya esté comprometido.

5.8. Seguridad de las conexiones inalámbricas

Las redes Wi-Fi presentan una característica particular: el medio de transmisión es compartido y las señales pueden ser recibidas por dispositivos situados dentro de la zona de cobertura.

Por ello, una red inalámbrica debe utilizar mecanismos adecuados de autenticación y protección criptográfica.

Los principales estándares históricos pueden resumirse de la siguiente manera:

WEP Protocolo de seguridad obsoleto y vulnerable. No debe utilizarse.

WPA Primera evolución de WEP. Se considera obsoleto y no debe utilizarse en sistemas actuales.

WPA2 Introdujo mecanismos de seguridad mucho más robustos, especialmente mediante AES-CCMP. Aunque sigue presente en numerosos sistemas, debe utilizarse con una configuración adecuada y claves resistentes.

WPA3 Estándar más moderno que mejora diferentes aspectos de seguridad de WPA2. En redes personales utiliza SAE en lugar del mecanismo PSK tradicional de WPA2.

En consecuencia, para una infraestructura nueva debe priorizarse **WPA3**. Cuando sea necesario mantener compatibilidad con dispositivos que no lo soporten, puede utilizarse WPA2 correctamente configurado.

Medidas básicas de protección Wi-Fi

Entre las medidas recomendables se encuentran:

1. Utilizar **WPA3** cuando sea compatible con los dispositivos.
2. Mantener **WPA2-AES/CCMP** como alternativa cuando WPA3 no sea posible.
3. Utilizar contraseñas suficientemente largas y resistentes en redes personales.
4. Mantener actualizado el firmware del punto de acceso.

5. Cambiar las credenciales de administración predeterminadas.
6. Desactivar mecanismos de administración remota que no sean necesarios.
7. Desactivar **WPS** cuando no sea necesario.
8. Separar las redes de invitados de la red interna cuando el dispositivo lo permita.
9. Utilizar WPA2-Enterprise o WPA3-Enterprise en entornos corporativos cuando sea necesario un sistema de autenticación individual.

El **filtrado de direcciones MAC** y la ocultación del SSID no deben considerarse mecanismos de protección suficientes. Una dirección MAC puede ser observada y suplantada y la ocultación del SSID no impide que un atacante pueda descubrir la existencia de la red.

Actualización

WEP debe considerarse completamente obsoleto. Asimismo, WPA y las configuraciones basadas en TKIP no son apropiadas para nuevas instalaciones. En redes actuales deben priorizarse WPA3 o, cuando sea necesario por compatibilidad, WPA2 con AES-CCMP.

5.9. Riesgos de las redes Wi-Fi públicas

Una red Wi-Fi pública puede presentar riesgos adicionales porque el usuario normalmente no controla el punto de acceso ni conoce la identidad o las intenciones de los demás dispositivos conectados.

Entre las amenazas que deben considerarse destacan:

- **Interceptación del tráfico**, especialmente cuando una aplicación utiliza protocolos sin cifrado.
- **Ataques de intermediario (MitM)**, mediante los cuales un atacante intenta situarse entre los dos extremos de una comunicación.
- **Puntos de acceso fraudulentos**, que imitan redes legítimas para atraer a los usuarios.
- **Suplantación de servicios**, mediante técnicas como DNS Spoofing o DHCP Spoofing.
- **Robo de credenciales**, especialmente cuando el usuario accede a servicios sin una autenticación y un canal adecuadamente protegidos.

Un escenario especialmente conocido es el **Evil Twin**, en el que un atacante crea un punto de acceso que imita el nombre o las características de una red legítima. Un usuario puede conectarse al punto de acceso fraudulento creyendo que se trata de la red auténtica.

6. Seguridad en la red corporativa

Una **red corporativa** es una infraestructura de comunicaciones que interconecta redes y sistemas pertenecientes a una organización, normalmente distribuidos entre diferentes ubicaciones geográficas. Puede integrar redes LAN, redes inalámbricas, centros de datos, servicios en la nube y conexiones de acceso remoto.

En este tipo de entornos conviven diferentes tecnologías y protocolos, por lo que la seguridad no puede depender de una única medida. Es necesario combinar mecanismos de **prevención, monitorización, detección y respuesta**.

Cuando varias sedes se encuentran conectadas mediante Internet, las comunicaciones atraviesan infraestructuras que no están bajo el control directo de la organización. Por este motivo, resulta

especialmente importante utilizar mecanismos de protección de las comunicaciones, como las **VPN**, además de mecanismos de autenticación, segmentación de red, filtrado y monitorización.

En esta sección se estudian tres aspectos fundamentales de la seguridad de una red corporativa:

1. **Monitorización del tráfico**: permite conocer qué está sucediendo en la red y detectar anomalías.
2. **Detección de intrusos**: permite identificar comportamientos que pueden indicar un intento de ataque o una intrusión.
3. **Seguridad de las comunicaciones inalámbricas**: aborda las amenazas específicas de las redes Wi-Fi y los mecanismos empleados para protegerlas.

6.1. Monitorización del tráfico en redes

La **monitorización del tráfico de red** consiste en observar y analizar las comunicaciones que circulan por una infraestructura para conocer su funcionamiento, detectar anomalías y facilitar la resolución de problemas.

En una red corporativa, la monitorización cumple una doble función:

- **Operativa**: permite detectar problemas de rendimiento, pérdida de paquetes, saturación de enlaces o fallos de dispositivos.
- **Seguridad**: permite identificar patrones de tráfico anómalos, comunicaciones no autorizadas, escaneos, intentos de intrusión o posibles fugas de información.

Es importante diferenciar entre la monitorización orientada a la **captura y análisis de paquetes** y la monitorización orientada a la **supervisión de equipos y servicios**. Ambas proporcionan información complementaria.

6.1.1. Herramientas de captura y análisis del tráfico

Estas herramientas permiten capturar paquetes y analizar diferentes niveles de los protocolos de comunicación. Son especialmente útiles para estudiar el funcionamiento de una red y para investigar incidentes de seguridad.

Wireshark Analizador de protocolos de código abierto con interfaz gráfica. Permite capturar tráfico y examinar detalladamente los paquetes, incluyendo sus cabeceras y los campos correspondientes a los diferentes protocolos.

Es especialmente útil para el análisis de protocolos, la resolución de problemas de red y la investigación de incidentes de seguridad.

tcpdump Herramienta de captura y análisis de tráfico basada en línea de comandos. Permite observar los paquetes que atraviesan una interfaz de red y aplicar filtros para limitar la información obtenida.

Su funcionamiento resulta especialmente apropiado para servidores y sistemas en los que no se dispone de una interfaz gráfica.

EtherApe Herramienta gráfica que representa visualmente las comunicaciones de una red. Permite obtener una visión general de los equipos que están intercambiando información y del volumen relativo de tráfico.

Idea clave

Las herramientas de captura de paquetes no determinan por sí mismas que una comunicación sea maliciosa. El análisis requiere interpretar los protocolos, las direcciones, los puertos, el contexto de la comunicación y el comportamiento habitual de la red.

6.1.2. Filtros de captura y filtros de visualización

Una captura de tráfico puede generar una cantidad de información muy elevada. Por ello, los analizadores de protocolos permiten utilizar filtros para seleccionar únicamente la información relevante.

Es necesario distinguir dos conceptos:

Filtros de captura
: Se aplican durante la captura y determinan qué paquetes serán almacenados. Permiten reducir desde el principio la cantidad de tráfico recopilado.

Filtros de visualización
: Se aplican sobre una captura ya realizada y permiten seleccionar qué paquetes se muestran al analista, sin modificar la captura original.

En una investigación puede ser conveniente conservar una captura suficientemente amplia y utilizar posteriormente filtros de visualización para estudiar únicamente el tráfico de interés.

Por ejemplo, en Wireshark pueden utilizarse expresiones como:

- `host 192.168.1.1`: muestra tráfico relacionado con un determinado host.
- `port 443`: muestra tráfico asociado al puerto 443.
- `src host 192.168.1.1`: selecciona tráfico cuyo origen sea una determinada dirección IP.
- `dst host 192.168.1.254`: selecciona tráfico cuyo destino sea una determinada dirección IP.
- `src port 22`: selecciona tráfico cuyo puerto de origen sea el puerto 22.

Importante

Los filtros de captura y los filtros de visualización no son equivalentes. El primero determina qué tráfico se captura; el segundo permite seleccionar información de una captura que ya existe.

6.1.3. Herramientas de monitorización de redes y equipos

Además del análisis individual de paquetes, existen herramientas destinadas a supervisar de forma continua el estado de una infraestructura.

Estas soluciones pueden comprobar periódicamente diferentes parámetros:

- disponibilidad de equipos y servicios;
- utilización de CPU y memoria;
- disponibilidad y utilización de interfaces de red;
- latencia y pérdida de paquetes;
- estado de servidores y aplicaciones;
- cumplimiento de determinados umbrales;
- generación de alertas ante anomalías.

Un ejemplo tradicional es **Nagios**, utilizado para supervisar equipos y servicios y generar alertas cuando se detectan condiciones anómalas.

En entornos actuales también son habituales plataformas de observabilidad y monitorización capaces de centralizar métricas, registros y eventos de numerosos sistemas.

Idea clave

La captura de paquetes permite estudiar con detalle qué está ocurriendo en una comunicación concreta, mientras que la monitorización de infraestructura permite conocer de forma continuada el estado general de la red y de los servicios.

6.2. Detección de intrusos

La **detección de intrusos** tiene como objetivo identificar actividades que puedan indicar un acceso no autorizado, un intento de ataque o un comportamiento anómalo dentro de los sistemas o de la red.

Los sistemas destinados a esta finalidad reciben el nombre de **IDS** (*Intrusion Detection System*).

Un IDS analiza información procedente de los sistemas o de las comunicaciones y busca evidencias compatibles con actividades maliciosas. Para ello puede utilizar diferentes técnicas de detección.

6.2.1. Métodos de detección

Los sistemas de detección de intrusos suelen combinar dos enfoques principales:

Detección basada en firmas
: Busca patrones conocidos asociados a ataques o comportamientos maliciosos previamente identificados.

  Es especialmente eficaz frente a amenazas conocidas, pero puede tener dificultades para identificar ataques completamente nuevos o variantes que no coincidan con las firmas disponibles.

Detección basada en anomalías
: Establece un comportamiento considerado normal y busca desviaciones significativas respecto a dicho comportamiento.

  Puede facilitar la identificación de ataques desconocidos, aunque existe el riesgo de generar falsos positivos cuando una actividad legítima se aleja del comportamiento habitual.

Concepto fundamental

La detección basada en firmas busca reconocer comportamientos conocidos; la detección basada en anomalías busca identificar comportamientos que se apartan de un patrón considerado normal.

6.2.2. Tipos de sistemas de detección

Según el lugar en el que se realiza la observación, pueden distinguirse principalmente dos tipos de IDS:

HIDS — Host Intrusion Detection System
: Analiza la actividad de un sistema concreto. Puede utilizar información procedente de registros, procesos, archivos, conexiones de red o cambios en la configuración del sistema.

NIDS — Network Intrusion Detection System
: Analiza el tráfico de una red o segmento de red para detectar patrones asociados a ataques o actividades sospechosas.

Los NIDS necesitan disponer de visibilidad suficiente sobre el tráfico que se desea analizar. Dependiendo de la arquitectura de red, esto puede conseguirse mediante interfaces configuradas para recibir tráfico destinado a otros equipos, mediante puertos de monitorización del conmutador o mediante mecanismos de replicación del tráfico.

6.2.3. Sistemas de prevención de intrusos

Un **IPS** (*Intrusion Prevention System*) amplía el concepto de detección incorporando capacidades de prevención.

Mientras que un IDS normalmente genera una alerta cuando detecta una actividad sospechosa, un IPS puede situarse en el camino del tráfico para aplicar una acción, como:

- descartar paquetes;
- bloquear una conexión;
- limitar determinado tráfico;
- registrar el incidente;
- generar una alerta para el equipo de administración.

Por tanto, la diferencia fundamental puede resumirse de la siguiente forma:

Tecnología	Función principal	Ámbito habitual
HIDS	Detectar actividad sospechosa en un sistema	Host individual
NIDS	Detectar actividad sospechosa en el tráfico de red	Segmento o red
IPS	Detectar y aplicar medidas de prevención	Tráfico en tránsito

Una herramienta conocida dentro de este ámbito es **Snort**, que puede utilizarse como sistema de detección y, mediante configuraciones y arquitecturas apropiadas, integrarse en soluciones de prevención.

6.3. Comunicaciones inalámbricas

Las redes inalámbricas permiten transmitir información mediante señales de radio, eliminando la necesidad de utilizar un medio físico entre el dispositivo cliente y el punto de acceso.

Su flexibilidad y movilidad hacen que sean fundamentales en las redes corporativas actuales, pero también introducen riesgos específicos. El medio radioeléctrico puede ser accesible desde fuera de los límites físicos de la organización, por lo que un atacante situado dentro del alcance radio puede intentar observar, interferir o acceder a la infraestructura.

Entre las principales amenazas se encuentran:

1. **Interceptación de comunicaciones**: captura de tráfico transmitido por radio.
2. **Acceso no autorizado**: conexión de dispositivos que no deberían disponer de acceso.
3. **Interferencias**: alteración deliberada o accidental de las comunicaciones.

4. **Denegación de servicio**: interrupción o degradación de la disponibilidad de la red.
5. **Rogue Access Point**: instalación de un punto de acceso no autorizado dentro de la infraestructura.
6. **Evil Twin**: creación de un punto de acceso que imita a uno legítimo para engañar a los usuarios.
7. **Ingeniería social**: obtención de credenciales mediante engaño al usuario.

6.3.1. Estándares IEEE 802.11

La familia **IEEE 802.11** define los estándares utilizados para las redes locales inalámbricas (WLAN).

El documento original recoge numerosos estándares y modificaciones. Entre los más relevantes desde el punto de vista histórico y tecnológico pueden destacarse:

802.11a Introdujo redes inalámbricas en la banda de 5 GHz y alcanzaba una tasa máxima teórica de 54 Mbit/s.

802.11b Operaba en 2,4 GHz y alcanzaba una tasa máxima teórica de 11 Mbit/s.

802.11g Operaba en 2,4 GHz y proporcionaba hasta 54 Mbit/s de tasa física teórica, manteniendo compatibilidad con 802.11b.

802.11n Introdujo mejoras importantes como MIMO y permitió utilizar las bandas de 2,4 y 5 GHz. Se comercializó ampliamente bajo la denominación Wi-Fi 4.

802.11ac Mejoró considerablemente el rendimiento en la banda de 5 GHz y se asocia habitualmente con Wi-Fi 5.

802.11ax Introdujo mejoras de eficiencia y capacidad, especialmente en entornos con muchos dispositivos conectados. Se conoce comercialmente como Wi-Fi 6 y Wi-Fi 6E cuando se utiliza también la banda de 6 GHz.

802.11be Corresponde a Wi-Fi 7 y amplía las capacidades de las generaciones anteriores mediante tecnologías destinadas a incrementar el rendimiento, reducir la latencia y mejorar la eficiencia de las redes inalámbricas.

Actualización

Los estándares antiguos como 802.11a/b/g continúan siendo importantes desde el punto de vista histórico, pero no deberían utilizarse como referencia para diseñar una infraestructura inalámbrica corporativa moderna. Actualmente deben considerarse especialmente las generaciones Wi-Fi 6/6E y Wi-Fi 7, dependiendo de los requisitos de la infraestructura.

6.3.2. Seguridad de las comunicaciones inalámbricas

La seguridad de una WLAN debe garantizar, como mínimo, que únicamente los dispositivos autorizados puedan acceder a la red y que las comunicaciones estén protegidas frente a la captura o manipulación.

Entre las medidas que pueden emplearse se encuentran:

- utilización de mecanismos robustos de autenticación;
- cifrado de las comunicaciones;

- utilización de contraseñas suficientemente robustas;
- actualización del firmware de los puntos de acceso;
- desactivación de servicios de administración innecesarios;
- desactivación de WPS cuando no sea necesario;
- segmentación de las redes inalámbricas;
- monitorización de puntos de acceso no autorizados;
- utilización de mecanismos de autenticación empresarial cuando sea necesario;
- separación de las redes corporativas y las redes destinadas a invitados.

6.3.3. Filtrado de direcciones MAC y ocultación del SSID

El **filtrado de direcciones MAC** permite establecer qué direcciones físicas pueden asociarse a un punto de acceso.

Sin embargo, no debe considerarse un mecanismo de autenticación fuerte. Las direcciones MAC pueden observarse en el tráfico inalámbrico y, dependiendo del escenario, pueden ser suplantadas. Además, la administración manual de grandes listas de direcciones resulta poco escalable.

Por ello, el filtrado MAC puede utilizarse como una medida complementaria, pero no como sustituto de un mecanismo robusto de autenticación.

La **ocultación del SSID** consiste en evitar que el nombre de la red aparezca de forma normal en determinados anuncios del punto de acceso. Esta medida tampoco constituye un mecanismo de seguridad suficiente, ya que el SSID puede ser obtenido mediante el análisis del tráfico de gestión.

Por tanto, tanto el filtrado MAC como la ocultación del SSID deben considerarse medidas auxiliares y no mecanismos de protección fundamentales.

6.3.4. Mecanismos de cifrado: WEP, WPA, WPA2 y WPA3

La seguridad de las redes Wi-Fi ha evolucionado mediante diferentes mecanismos.

WEP

Fue uno de los primeros mecanismos de protección de redes 802.11. Utilizaba RC4 y presentaba importantes debilidades criptográficas que permiten recuperar las claves mediante el análisis de suficiente tráfico.

WEP debe considerarse obsoleto y no debe utilizarse en una infraestructura actual.

WPA

Se introdujo como solución transitoria ante las deficiencias de WEP. Incorporó mecanismos como TKIP y 802.1X.

Aunque supuso una mejora respecto a WEP, actualmente también se considera un mecanismo obsoleto.

WPA2

Basado en el estándar IEEE 802.11i, generalizó el uso de mecanismos robustos de seguridad y, especialmente, de AES-CCMP.

WPA2-Personal utiliza una clave precompartida (*PSK*), mientras que WPA2-Enterprise emplea mecanismos basados en 802.1X y EAP.

WPA3

Constituye la generación posterior de seguridad Wi-Fi y mejora diferentes aspectos de WPA2. En el modo Personal utiliza SAE (*Simultaneous Authentication of Equals*) en lugar del mecanismo PSK tradicional para el establecimiento de la autenticación.

WPA3 también dispone de una modalidad Enterprise basada en infraestructura de autenticación y mecanismos EAP.

Seguridad actual

No deben utilizarse WEP ni WPA como mecanismos de seguridad en nuevas instalaciones. También debe evitarse el uso de TKIP. En infraestructuras modernas se debe priorizar WPA3, manteniendo WPA2 con AES-CCMP únicamente cuando existan requisitos de compatibilidad con dispositivos que todavía no soporten WPA3.

6.3.5. Ataques mediante puntos de acceso falsos

Una amenaza característica de las redes inalámbricas es la creación de un **Rogue Access Point**, es decir, un punto de acceso no autorizado conectado a la infraestructura de la organización.

Un caso especialmente relevante es el denominado **Evil Twin**. En este escenario, el atacante crea un punto de acceso que imita las características de una red legítima, por ejemplo, utilizando un SSID similar o idéntico.

Si un usuario se conecta al punto de acceso fraudulento, el atacante puede intentar:

- observar o manipular determinadas comunicaciones;
- redirigir al usuario hacia servicios controlados por el atacante;
- obtener credenciales mediante páginas fraudulentas;
- realizar ataques de intermediario (*Man-in-the-Middle*);
- recopilar información sobre los dispositivos conectados.

La utilización de cifrado y autenticación robustos reduce considerablemente las posibilidades de éxito de este tipo de ataques, pero la protección debe complementarse con mecanismos de monitorización que permitan detectar puntos de acceso no autorizados.

6.3.6. Servidores de autenticación y WPA-Enterprise

En redes corporativas con un número elevado de usuarios, compartir una única contraseña entre todos los dispositivos presenta importantes problemas de gestión.

Por ejemplo, cuando un empleado abandona la organización, sería necesario modificar la contraseña compartida de toda la red si se quisiera impedir que dicho usuario siguiera utilizándola.

Una alternativa es utilizar **WPA-Enterprise**, basado en **IEEE 802.1X** y mecanismos de autenticación **EAP**.

La arquitectura básica está formada por tres elementos:

1. **Supplicant**: dispositivo o software del cliente que solicita acceso a la red.
2. **Authenticator**: elemento que controla el acceso a la red. Habitualmente es el punto de acceso inalámbrico.
3. **Authentication Server**: servidor que verifica las credenciales o certificados del usuario. Habitualmente se utiliza un servidor RADIUS.

El funcionamiento general puede resumirse de la siguiente forma:

1. El cliente solicita acceso a la red inalámbrica.
2. El punto de acceso actúa como autenticador y comienza el proceso de autenticación 802.1X.
3. El intercambio de autenticación se realiza mediante EAP.
4. El autenticador comunica la información necesaria al servidor de autenticación.

5. El servidor RADIUS valida las credenciales mediante el método EAP configurado.
6. Si la autenticación es correcta, el autenticador permite el acceso a la red.
7. A partir de ese momento se establecen las claves necesarias para proteger las comunicaciones.

Entre las ventajas de este modelo destacan:

- autenticación individual de los usuarios;
- posibilidad de revocar el acceso de un usuario sin modificar las credenciales del resto;
- centralización de la gestión de identidades;
- posibilidad de utilizar certificados digitales;
- registro de los accesos realizados;
- integración con directorios y sistemas corporativos de identidad.

Algunos métodos EAP pueden utilizar certificados digitales y TLS, como **EAP-TLS**, mientras que existen otros métodos basados en túneles seguros, como **PEAP**.

6.3.7. Servidor RADIUS

RADIUS (*Remote Authentication Dial-In User Service*) es un protocolo ampliamente utilizado para centralizar servicios de autenticación, autorización y contabilidad (AAA).

En una infraestructura Wi-Fi empresarial, el punto de acceso no tiene por qué almacenar directamente las credenciales de todos los usuarios. En su lugar, puede consultar al servidor RADIUS para determinar si un usuario está autorizado.

De forma simplificada:

Cliente
↓
Punto de acceso / Authenticator
↓
Servidor RADIUS
↓
Sistema de identidad

El uso de RADIUS resulta especialmente apropiado en organizaciones con numerosos usuarios y dispositivos, donde la gestión centralizada de las identidades simplifica la administración de la red.

6.3.8. Portal cautivo

Un **portal cautivo** es un mecanismo que controla el acceso de los usuarios a una red mediante una página de autenticación o autorización.

Es habitual encontrarlo en redes Wi-Fi de hoteles, universidades, aeropuertos, centros educativos y redes de invitados.

El funcionamiento básico es:

1. El dispositivo se conecta al punto de acceso.
2. La red permite inicialmente una conectividad limitada.
3. Cuando el usuario intenta acceder a determinados servicios, es redirigido al portal de autenticación.

4. El usuario introduce sus credenciales, acepta las condiciones de uso o introduce un código de acceso.
5. El sistema valida la operación.
6. Si la autorización es correcta, se habilita el acceso a los servicios permitidos.

Un portal cautivo puede proporcionar funcionalidades adicionales, como:

- limitación del número de conexiones simultáneas;
- control del tiempo de conexión;
- desconexión tras un periodo de inactividad;
- limitación del ancho de banda;
- autenticación mediante usuario y contraseña;
- utilización de códigos o *vouchers*;
- integración con RADIUS;
- registro de sesiones;
- redirección hacia una página determinada después de la autenticación.

Importante

Un portal cautivo controla el acceso a una red o servicio, pero no debe confundirse con el cifrado de las comunicaciones Wi-Fi. La protección criptográfica de la red debe proporcionarse mediante los mecanismos de seguridad correspondientes, mientras que el portal cautivo añade una capa de control y autorización.